CEH v13 Module 16 - Hacking Wireless Networks

CEH v13 AI (312-50) Study Guide

Exam-focused notes built from module screenshots

Table of Contents

1. Module at a Glance
2. Big Picture Map
3. Topic-by-Topic Guide
    - 3.1 Learning Objectives of Module 16
    - 3.2 Wireless Networks and Types of Wireless Networks
    - 3.3 Wireless Standards
    - 3.4 Wi-Fi Authentication Process
    - 3.5 Wireless Encryption: Wired Equivalent Privacy (WEP)
    - 3.6 Wireless Encryption: Wi-Fi Protected Access (WPA)
    - 3.7 Wireless Encryption: WPA2
    - 3.8 Wireless Encryption: WPA3
    - 3.9 Comparison and Issues of WEP, WPA, WPA2, and WPA3
    - 3.10 Wireless Threats
    - 3.11 Wireless Hacking Methodology
    - 3.12 Wi-Fi Discovery: Wireless Network Footprinting
    - 3.13 Wi-Fi Discovery: Finding Wi-Fi Networks in Range to Attack
    - 3.14 Wi-Fi Discovery: Finding WPS-Enabled APs
    - 3.15 Wireless Traffic Analysis
    - 3.16 Choosing the Optimal Wi-Fi Card
    - 3.17 Launch of Wireless Attacks: Aircrack-ng Suite
    - 3.18 Launch of Wireless Attacks: Detection of Hidden SSIDs
    - 3.19 Launch of Wireless Attacks: Denial-of-Service (Disassociation and De-authentication)
    - 3.20 Launch of Wireless Attacks: Man-in-the-Middle Attack
    - 3.21 Launch of Wireless Attacks: MAC Spoofing Attack
    - 3.22 Launch of Wireless Attacks: Wireless ARP Poisoning Attack
    - 3.23 Launch of Wireless Attacks: Rogue Access Points
    - 3.24 Launch of Wireless Attacks: Evil Twin
    - 3.25 Launch of Wireless Attacks: Key Reinstallation Attack (KRACK)
    - 3.26 Launch of Wireless Attacks: Jamming Signal Attack
    - 3.27 Launch of Wireless Attacks: aLTEr Attack
    - 3.28 Launch of Wireless Attacks: Wi-Jacking Attack
    - 3.29 Launch of Wireless Attacks: RFID Cloning Attack

3.30 Wi-Fi Encryption Cracking: WPA/WPA2
3.31 WPA Brute Forcing Using Fern Wifi Cracker
3.32 WPA3 Encryption Cracking (Dragonblood)
3.33 Cracking WPA3 Using Aircrack-ng and Hashcat
3.34 Cracking WPS Using Reaver
3.35 Wireless Attack Countermeasures (WPA/WPA2/WPA3 and aLTEr)
3.36 Detection and Blocking of Rogue APs
3.37 Defense Against Wireless Attacks (Best Practices)
3.38 Wi-Fi Security Auditing Tools
4. Tool Encyclopedia
5. Command Sheet
5.1 airmon-ng
5.2 airodump-ng
5.3 aireplay-ng
5.4 aircrack-ng
5.5 mdk3 (hidden SSID brute force)
5.6 Wash and Reaver (WPS attack chain)
5.7 MAC spoofing (ifconfig / ip link)
5.8 hashcat (WPA/WPA3 handshake cracking)
6. Ports, Protocols, Standards and Acronyms
7. Attack vs Countermeasure and Look-alike Comparisons
8. Exam Cheat Sheet
9. Practice Questions
10. Flashcards
11. Glossary
12. Coverage Report

CEH v13 AI (312-50) Study Guide - Module 16: Hacking Wireless Networks

Source: 26 pages of screenshots from the official Module 16 theory videos (slides 2 to 52). Content marked "ADDED CONTEXT" comes from outside the screenshots. Items marked "verify" should be checked against current official sources. Items marked [UNCLEAR on page N] were too small, blurry, or partly covered by artwork to read with full confidence.

1. Module at a Glance

Module: 16 - Hacking Wireless Networks (EC-Council CEH v13 AI).

What this module is (5 lines):

1. It explains how Wi-Fi networks work: standards, authentication modes, and the four encryption schemes WEP, WPA, WPA2, and WPA3.
2. It groups wireless threats into five families: access control, integrity, confidentiality, availability, and authentication attacks.
3. It walks through the wireless hacking methodology in five stages: discovery, traffic analysis, launching attacks, encryption cracking, and compromising the network, with real tool screenshots for each.
4. It names the attack toolkit: Aircrack-ng suite, Wash, Reaver, Fern Wifi Cracker, Ettercap, MANA Toolkit, hashcat, and RFID cloning tools.
5. It ends with countermeasures and Wi-Fi security auditing tools such as Cisco Adaptive WIPS and WatchGuard Wi-Fi Cloud WIPS.

Why it matters: Wireless networks remove the cable, so the usual assumption "an attacker must be plugged into my LAN" no longer applies. Anyone within radio range is a potential attacker. The exam leans hard on this module for the Aircrack-ng command chain, the WEP/WPA/WPA2/WPA3 comparison table, and telling similar attacks apart (Evil Twin vs Rogue AP vs MITM, Disassociation vs De-authentication, KRACK vs Dragonblood).

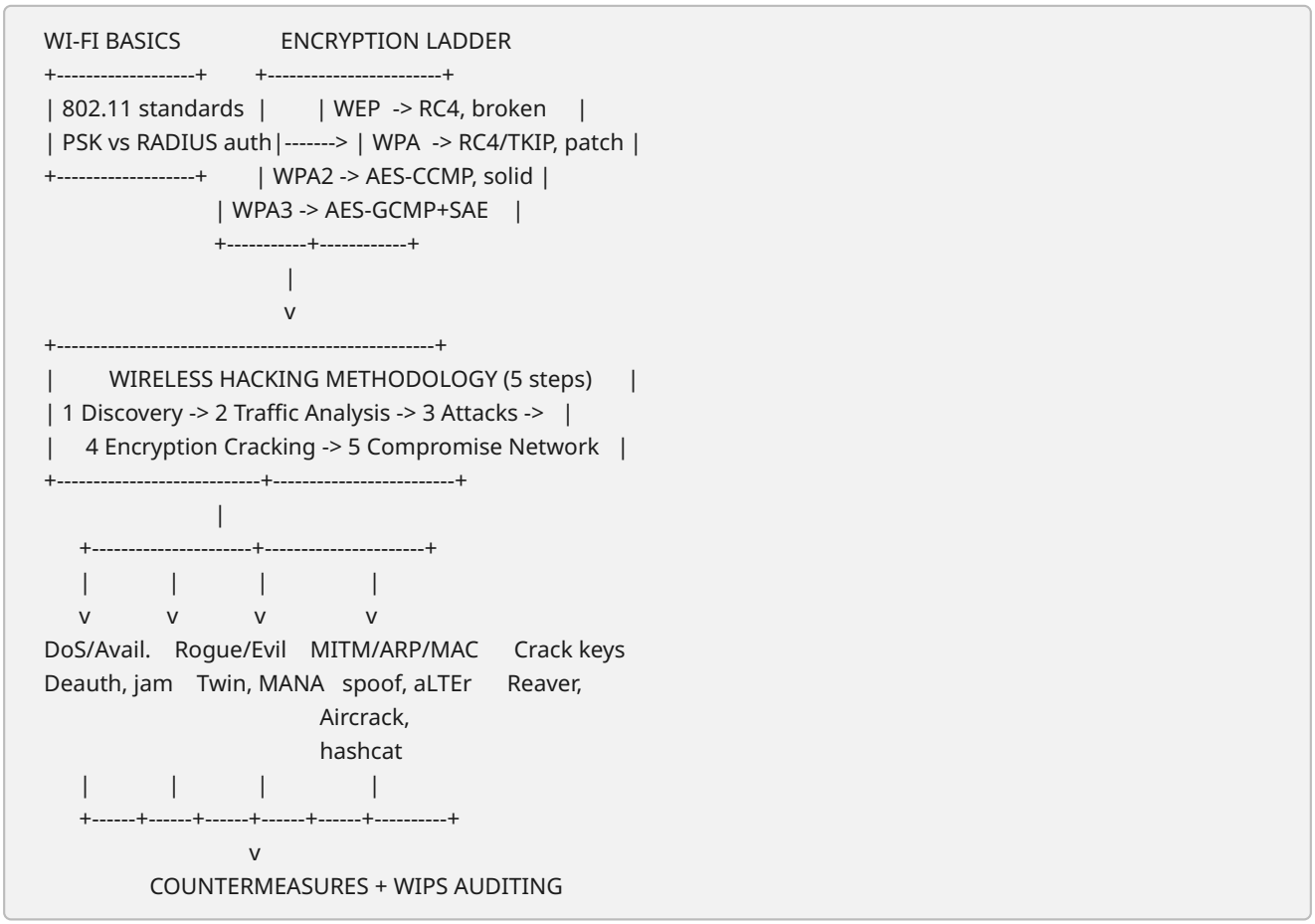
What the exam usually asks from it:

- Which encryption standard (WEP/WPA/WPA2/WPA3) uses which cipher, key size, IV size, and integrity check.
- Which Aircrack-ng suite tool does a given job (airmon-ng, airodump-ng, aireplay-ng, aircrack-ng, airdecap-ng, airdrop-ng, airolib-ng, airbase-ng).
- Which wireless threat category a scenario belongs to (access control, integrity, confidentiality, availability, authentication).
- How the 4-way handshake works and how KRACK abuses it.
- What a specific attack is: Evil Twin, Rogue AP, MITM, MAC spoofing, ARP poisoning, jamming, aLTEr, Wi-Jacking, RFID cloning.
- Which countermeasure or best practice fixes a given weakness.
- Reading an aircrack-ng/airodump-ng/reaver command and its output.

The 10 things to remember most:

1. Five-step wireless hacking methodology: Wi-Fi Discovery, Wireless Traffic Analysis, Launch of Wireless Attacks, Wi-Fi Encryption Cracking, Compromise the Wi-Fi Network.
2. WEP = RC4 + 24-bit IV + CRC-32, broken and obsolete. WPA = RC4/TKIP + 48-bit IV + Michael algorithm, a patch for WEP. WPA2 = AES-CCMP, mandatory strong encryption. WPA3 = AES-GCMP-256 + SAE (Dragonfly).
3. The 4-way handshake (WPA2) exchanges ANonce and SNonce to build the session keys; KRACK forces nonce reuse in message 3.
4. Aircrack-ng suite: airmon-ng (monitor mode), airodump-ng (capture), aireplay-ng (injection/deauth), aircrack-ng (crack the key), airdecap-ng (decrypt captured traffic), airolib-ng (password/ESSID database), airbase-ng (fake AP), airdrop-ng (targeted deauth).
5. Five wireless threat families: Access Control, Integrity, Confidentiality, Availability, Authentication attacks.
6. Disassociation attack removes one client from one AP (client can still re-authenticate quickly); De-authentication attack fully kicks the client off (must re-authenticate and re-associate). Command: aireplay-ng --deauth.
7. Evil Twin = rogue AP that copies a legitimate SSID to trick users; Rogue AP = any unauthorized AP attached to the network (does not need to copy an SSID); MITM = attacker sits between client and AP after deauth plus a fake AP, reading all traffic.
8. WPA3 uses SAE (Simultaneous Authentication of Equals, also called Dragonfly Key Exchange) which resists offline dictionary attacks; Dragonblood is the set of flaws that still affects some WPA3 implementations.
9. Cracking tools by job: Wash finds WPS-enabled APs; Reaver brute forces the WPS PIN; aircrack-ng/hashcat crack the captured WPA/WPA2 handshake with a wordlist; Fern Wifi Cracker gives a GUI for the same workflow.
10. Defense basics: WPA3-SAE where possible, AES only (disable TKIP and WEP), strong 12 to 16 character passphrase, WPS off, MAC filtering plus 802.1X/RADIUS for enterprise, hidden SSID is weak but still a layer, monitor with a WIPS.

2. Big Picture Map



How the threat families map to real attacks seen in the notes:

Threat family	Meaning	Attacks named in notes
Access control	Bypass who may join	MAC spoofing, AP misconfig
Integrity	Forge frames	WEP injection, bit-flipping
Confidentiality	Steal traffic content	Evil Twin, MITM, sniffing
Availability	Deny service	Deauth, jamming, beacon flood
Authentication	Steal identity/creds	PSK cracking, KRACK, Reaver

3. Topic-by-Topic Guide

The sections below follow the order of the screenshots.

3.1 Learning Objectives of Module 16

What it is: The opening slide lists five goals that structure the whole module and this guide.

1. Summarize wireless concepts.
2. Explain different wireless encryption algorithms.

3. Explain different wireless threats.
4. Demonstrate wireless hacking methodology.
5. Explain wireless attack countermeasures.

EXAM FOCUS: Expect at least one question from each objective: concepts (standards, authentication), encryption (WEP/WPA/WPA2/WPA3), threats (the five families), methodology (five steps and the tools used in each), and countermeasures (best practices and WIPS tools).

Memory trick: "Concepts, Codes, Crooks, Crack, Cure" -> wireless Concepts, encryption Codes, threat Crooks, hacking methodology (Crack), and Cure (countermeasures).

3.2 Wireless Networks and Types of Wireless Networks

What it is (simple words): A wireless network (Wi-Fi) is a WLAN (wireless local area network) built on the IEEE 802.11 standard. It lets a device join a network from anywhere inside the range of an access point (AP), which is the device that bridges wireless clients to a wired network.

- **Access point (AP):** hardware that lets wireless devices connect to a wired network, usually to the internet, using radio signals.
- **WLAN:** a local network where devices connect over radio waves instead of cables.

Analogy: A Wi-Fi AP is like a radio tower for a small town. Any radio with the right tuning (SSID and key) that is close enough to the tower can join the broadcast.

How it works (numbered steps, general Wi-Fi join):

1. The AP broadcasts its presence (beacon frames) or waits for a probe.
2. A client scans for or probes for nearby APs.
3. The client authenticates and associates with the chosen AP.
4. The AP bridges the client's traffic to the wired network or internet.

Four network layouts shown in the notes:

Layout	What it looks like
Extension to a wired network	Users -> AP -> broadband router -> Internet
Multiple access points	Users -> AP -> AP -> broadband router -> Internet
LAN-to-LAN wireless	LAN 1 -> broadband router <-> broadband router -> LAN 2
3G/4G/5G hotspot	Users -> hotspot (3G/4G/5G USB) -> cell tower -> Internet

Real-world use: A small office extends its wired LAN with one AP so staff can use laptops anywhere in the room (extension to a wired network). A campus adds many APs so a student keeps one connection while walking between buildings (multiple access points, same SSID, roaming).

Tools and commands used here: None specific; later sections give the discovery and attack tools.

Countermeasures and defense: Place APs away from windows and exterior walls to shrink the usable signal area outside the building.

EXAM FOCUS: A question may describe a scenario (a phone tethering a laptop to the internet over USB and Wi-Fi) and ask which layout it is. Match "cell tower" and "USB" to the 3G/4G/5G hotspot layout.

Memory trick: "E-M-L-H": Extension, Multiple AP, LAN-to-LAN, Hotspot.

3.3 Wireless Standards

What it is: The IEEE 802.11 family defines how Wi-Fi radios talk: frequency band, modulation method, maximum speed, and range. The table below is the one shown in the notes; "verify" marks a figure that looks unusual and should be checked against current official sources.

Amendment	Frequency (GHz)	Speed (Mbps)	Range (m)
802.11 (Wi-Fi)	2.4	1, 2	20 to 100
802.11a	5 (3.7 variant exists)	up to 54	35 to 100
802.11b	2.4	1, 2, 5.5, 11	35 to 140
802.11g	2.4	up to 54	38
802.11n	2.4, 5	54 to 600	70 to 250
802.11ax (Wi-Fi 6)	2.4 to 5	up to 2400	240
802.11be (Wi-Fi 7)	2.4, 5, 6	up to 3000	120

Modulation used by each: 802.11 uses DSSS/FHSS; 802.11a/g use OFDM; 802.11b uses DSSS; 802.11n uses MIMO-OFDM; 802.11ax uses 1024-QAM; 802.11be uses QAM (verify exact QAM order).

Amendments that are not raw speed specs but feature add-ons:

- **802.11d:** adds global roaming by allowing variation in frequency, power, and bandwidth across countries.
- **802.11e:** adds Quality of Service (QoS), prioritizing voice and video traffic over plain data.
- **802.11i:** defines strong encryption (WPA2-Enterprise and WPA2-Personal) for use with 802.11a/b/g radios.

Related short-range and long-range wireless standards also listed:

Standard	Common name	Frequency (GHz)	Range (m)
802.15.1	Bluetooth	2.4	10 to 240
802.15.4	ZigBee	0.868/0.915/2.4	1 to 100

Standard	Common name	Frequency (GHz)	Range (m)
802.16	WiMAX	2 to 11	up to about 9656 (1-6 miles)

> **ADDED CONTEXT:** Bluetooth (802.15.1) uses GFSK, pi/4-DPSK, and 8DPSK modulation. ZigBee (802.15.4) uses O-QPSK, GFSK, or BPSK and is common in home automation and IoT sensors because of its very low power use. WiMAX (802.16) uses SOFDMA and targets metro-area wireless broadband, not local Wi-Fi.

Analogy: Each amendment is a software update to the same radio language. Letters added later (n, ac, ax) usually mean faster and longer range, similar to phone generations (3G, 4G, 5G).

Real-world use: A warehouse picks 802.11n for its 2.4 GHz range and wall penetration; a stadium picks 802.11ax for its ability to serve many devices in a crowd without slowing down.

EXAM FOCUS: Memorize which amendment is a security or QoS feature (802.11d, e, i) versus a speed amendment (a, b, g, n, ax, be). A question that says "enables global roaming across power and frequency limits" means 802.11d, not a speed standard.

Memory trick: "d for drift (across countries), e for entertainment (QoS for voice/video), i for iron security (WPA2)."

3.4 Wi-Fi Authentication Process

What it is (simple words): Before a client can send normal traffic, it must authenticate to the AP. The notes show two modes: Pre-Shared Key (PSK) and centralized (RADIUS) authentication.

Pre-Shared Key (PSK) mode, also called WPA-PSK or WPA2-PSK, uses one shared password for every device on the network.

How it works (PSK, numbered steps):

1. Client sends an authentication request to the AP.
2. AP sends a challenge text.
3. Client encrypts the challenge text (using the shared key) and sends it back.
4. AP decrypts the response; if it matches, the client is authenticated.
5. Client connects to the network.

Analogy: PSK is like a building that gives the same door code to every tenant. Easy to manage, but if one tenant leaks the code, everyone is affected and the whole lock must be re-coded.

Centralized authentication mode (RADIUS) uses a Remote Authentication Dial-In User Service (RADIUS) server to issue unique keys per user instead of one shared password.

- **RADIUS server:** a centralized server that checks username and password (or certificate) and tells the AP whether to let a client in.
- **EAP (Extensible Authentication Protocol):** the framework RADIUS and 802.1X use to carry different authentication methods (passwords, tokens, certificates) between client, AP, and server.

How it works (RADIUS, numbered steps):

1. Client requests a connection to the AP.
2. AP sends an EAP-Request asking the client to identify itself.
3. Client replies with an EAP-Response containing its identity.
4. AP forwards the identity to the RADIUS server over the uncontrolled port (the port that only allows authentication traffic, not full network access).
5. RADIUS server sends a request to the client, through the AP, specifying which authentication mechanism to use.
6. Client responds to the RADIUS server with its credentials, through the AP.
7. If credentials are acceptable, the RADIUS server sends an encrypted authentication key to the AP.
8. AP sends a multicast/global authentication key to the client, encrypted with a per-station unicast session key.

Real-world use: A coffee shop uses PSK: every customer types the same Wi-Fi password printed on a receipt. A university uses RADIUS (802.1X): each student logs in with their own student ID and password, so IT can revoke one student's access without changing the password for everyone else.

Tools and commands used here: None in this topic; cracking tools for PSK appear in section 3.30.

Countermeasures and defense: Prefer RADIUS/802.1X for any network with many users or sensitive data; rotate the PSK regularly and avoid a guessable passphrase if PSK must be used.

EXAM FOCUS: "Which authentication mode assigns unique credentials per user?" -> centralized/RADIUS. "Which mode uses one shared password?" -> PSK. Keyword "uncontrolled port" belongs to the 802.1X/RADIUS flow, not PSK.

Memory trick: "PSK = Pass Shared by Kin (everyone the same). RADIUS = Really Assigns Distinct Individual User Secrets."

3.5 Wireless Encryption: Wired Equivalent Privacy (WEP)

What it is (simple words): WEP is the original 802.11b security protocol. It tried to give wireless traffic privacy similar to a wired LAN, but its design is broken and it should never be used today.

- **RC4:** a stream cipher that turns a key into a long pseudo-random keystream, which is then XORed with the data to encrypt it.
- **Initialization Vector (IV):** a short random value mixed with the key so the same plaintext does not always produce the same ciphertext. WEP's IV is only 24 bits, which is far too small.
- **CRC-32:** a checksum used to detect accidental errors, not a secure integrity check against a deliberate attacker.

Analogy: WEP is like a padlock whose combination resets by mixing in only two extra dial clicks (the tiny 24-bit IV). An attacker who watches long enough will see the same two clicks come up again and can work out the lock's pattern.

How it works (numbered steps, from the WEP diagram):

1. The WEP key store holds up to four keys (K1 to K4).
2. One key is combined with an IV to build the WEP seed.
3. The WEP seed feeds the RC4 cipher, which outputs a keystream.
4. In parallel, the plaintext data is passed through a CRC-32 checksum to produce an Integrity Check Value (ICV).
5. Data and ICV are XORed with the RC4 keystream to produce ciphertext.
6. The frame is sent as IV + PAD + Key ID (KID), followed by the ciphertext, inside the MAC frame body.

Real-world use: An old warehouse barcode scanner from the 2000s still only supports WEP. A pentester quickly cracks the WEP key in minutes using Aircrack-ng, proving the device must be replaced or moved to an isolated VLAN.

Tools and commands used here: Aircrack-ng suite (section 3.17 and 3.30) is the classic WEP-cracking toolkit.

Countermeasures and defense: Do not use WEP. Replace any WEP-only device, or isolate it on its own segment with no access to sensitive systems.

EXAM FOCUS: "Which protocol uses a 24-bit IV and RC4?" -> WEP. "Which checksum does WEP use for integrity, and why is it weak?" -> CRC-32, because it only catches random errors, not intentional tampering (no cryptographic key is involved in the checksum itself).

Memory trick: "WEP = Weak Encryption Protocol (unofficial but easy to remember): RC4 + tiny 24-bit IV + CRC-32."

3.6 Wireless Encryption: Wi-Fi Protected Access (WPA)

What it is (simple words): WPA is the 802.11i-era patch that fixed the worst WEP problems without needing new hardware. It still uses RC4, but wraps it with the Temporal Key Integrity Protocol (TKIP).

- **TKIP (Temporal Key Integrity Protocol):** mixes a new per-packet key for every frame, extends the IV, adds re-keying, and adds a message integrity check, so the same old RC4 engine becomes much harder to break.
- **MIC (Message Integrity Check):** a 64-bit check (using the "Michael" algorithm) that protects against forged or altered packets, something WEP's CRC-32 could not do.

Analogy: WPA keeps the same old engine (RC4) as WEP, but adds a turbocharger (TKIP) that changes the fuel mixture every single use (per packet key mixing) so the old engine's weaknesses are mostly hidden.

How it works (numbered steps, from the WPA diagram):

1. Build a temporal encryption key from the transmit address and the TSC (TKIP Sequence Counter, made of IV + Extended IV).
2. Mix the temporal key with the transmit address and TSC to build a per-packet WEP seed (key mixing stage).
3. Run the MAC Service Data Unit (MSDU, the data to transmit) through the Michael algorithm with the MIC key to produce MSDU + MIC.
4. Fragment the MSDU + MIC into MAC Protocol Data Units (MPDU).
5. Run each MPDU through a CRC-32 checksum to get the ICV.
6. XOR the data and ICV with the RC4 keystream (built from the WEP seed) to get the ciphertext.
7. Send the frame as MAC header + IV/EIV + Key ID + ciphertext.

Real-world use: A company upgrades its WEP routers' firmware to support WPA overnight, buying time until it can afford WPA2/WPA3 hardware. This stops the simplest key-recovery attacks that worked on WEP.

Tools and commands used here: Aircrack-ng suite (dictionary attack against the PSK, section 3.30).

Countermeasures and defense: Treat WPA as a stopgap, not a final answer; move to WPA2 or WPA3 as soon as hardware allows; disable TKIP.

EXAM FOCUS: "Which protocol adds per-packet key mixing and the Michael algorithm to fix WEP?" -> WPA/TKIP. Trap: WPA can still use RC4, so "uses RC4" alone does not prove a frame is WEP; check for TKIP markers (extended IV, MIC) to tell WPA from WEP.

Memory trick: "WPA = WEP Patched Again: same RC4 engine, new TKIP turbo (per-packet key, MIC, extended IV, re-keying)."

3.7 Wireless Encryption: WPA2

What it is (simple words): WPA2 is the full implementation of 802.11i. It replaces RC4/TKIP with AES in CCMP mode, a real modern block cipher scheme, and is mandatory for Wi-Fi Alliance certification.

- **CCMP (Counter mode with CBC-MAC Protocol):** an AES-based mode that gives both encryption (counter mode) and integrity (CBC-MAC) in one pass.
- **AES (Advanced Encryption Standard):** a strong block cipher, far more resistant to cryptanalysis than RC4.

Two modes of operation:

Mode	How it authenticates	Best fit
WPA2-Personal	Pre-shared key (PSK), 8-63 ASCII chars	Home, small office
WPA2-Enterprise	EAP/RADIUS, token cards, Kerberos	Enterprise networks

In WPA2-Personal, every device derives a 128-bit key from the shared passphrase. In WPA2-Enterprise, a centralized server issues unique login credentials per user.

Analogy: WPA2 is a brand-new engine (AES) instead of a patched old one (RC4). It is built for the job from the start, not retrofitted.

How it works (numbered steps, from the WPA2 MAC frame diagram):

1. Start from the MAC header (priority, destination address), the Packet Number (PN), the Temporal Key, and the plaintext data.
2. Build the Additional Authentication Data (AAD) from header fields.
3. Build a Nonce from the PN and other fields.
4. Feed Nonce, AAD, and plaintext into AES-CCMP.
5. Build a CCMP header carrying the PN and Key ID.
6. Output the final frame: MAC header + CCMP header + encrypted data + encrypted MIC.

Real-world use: A modern home router ships with WPA2-Personal by default. A bank's office uses WPA2-Enterprise with RADIUS so that each employee's Wi-Fi access can be revoked individually when they leave.

Tools and commands used here: Aircrack-ng and hashcat target the captured 4-way handshake (section 3.30, 3.33).

Countermeasures and defense: Use a long, random passphrase for Personal mode (not a dictionary word); use Enterprise mode with RADIUS wherever many users need distinct accountability.

EXAM FOCUS: "Which WPA2 mode uses a RADIUS server?" -> Enterprise. "Which integrity mechanism does WPA2 use?" -> CBC-MAC (inside CCMP), not the Michael algorithm (that is WPA/TKIP) and not CRC-32 (that is WEP).

Memory trick: "WPA2 = AES-CCMP for Confidentiality and Cryptographic Message Protection, no more RC4."

3.8 Wireless Encryption: WPA3

What it is (simple words): WPA3 is the newest generation, replacing WPA2's PSK exchange with a stronger method and upgrading the cipher to AES-GCMP-256.

- **SAE (Simultaneous Authentication of Equals), also called Dragonfly Key Exchange:** a password-based key exchange that resists offline dictionary attacks because each guess requires a live exchange with the AP, unlike WPA2's handshake which can be captured and brute forced offline.
- **GCMP-256:** Galois/Counter Mode Protocol with a 256-bit key, used for authenticated encryption.

Two modes of operation:

Mode	Key features
WPA3-Personal	SAE/Dragonfly auth; resists offline dictionary attacks
WPA3-Enterprise	GCMP-256, HMAC-SHA-384 key derivation, ECDSA-384 exchange

Analogy: WPA2's handshake is like leaving an envelope lying around that an attacker can pick up and try to open later, as many times as they want, in private (offline dictionary attack). WPA3's SAE is like a locked conversation that must happen live, each time, with the real door; the attacker cannot take it home to crack quietly.

Real-world use: A hospital upgrades its Wi-Fi infrastructure to WPA3-Enterprise to protect patient data with stronger authenticated encryption and resistance to password-guessing attacks.

Tools and commands used here: Dragonblood tool family (Dragonslayer, Dragonforce, Dragondrain, Dragontime) targets WPA3 flaws (section 3.32).

Countermeasures and defense: Enable WPA3 wherever all client devices support it; disable WPA2/WPA3 "transition mode" once every device can run pure WPA3, because transition mode re-opens WPA2-style attacks.

EXAM FOCUS: "Which key exchange is resistant to offline dictionary attacks?" -> SAE/Dragonfly (WPA3). "Which hash function builds WPA3- Enterprise keys?" -> HMAC-SHA-384. Trap: WPA3-Personal still uses a password (like WPA2-Personal); the difference is the exchange method (SAE vs the WPA2 4-way handshake with a PSK), not the presence of a password.

Memory trick: "WPA3: Stronger Authentication Everywhere - Dragonfly handshake, GCMP-256 cipher."

3.9 Comparison and Issues of WEP, WPA, WPA2, and WPA3

What it is: A side-by-side summary table and a list of known issues for each protocol generation, useful for quick exam recall.

Protocol	Cipher	IV size	Key length	Key mgmt	Integrity
WEP	RC4	24-bit	40/104-bit	None	CRC-32
WPA	RC4, TKIP	48-bit	128-bit	4-way handshake	Michael + CRC-32
WPA2	AES-CCMP	48-bit	128-bit	4-way handshake	CBC-MAC
WPA3	AES-GCMP-256	up to 2^64	192-bit	ECDH and ECDSA	BIP-GMAC-256

Overall verdict from the notes: WEP and WPA should be replaced; WPA2 protects against forgery and replay attacks; WPA3 gives enhanced password protection, secured IoT connections, and stronger encryption.

Known issues by protocol:

- **WEP issues:** CRC-32 gives no true cryptographic integrity; the 24-bit IV is sent in cleartext and repeats quickly; vulnerable to known-plaintext attacks; passwords are easy to crack; association and disassociation messages are not authenticated; an attacker can build a decryption table of reconstructed keystreams; there is no centralized key management; the IV being part of the RC4 key enables analytical (related-key) attacks.
- **WPA issues:** the pre-shared key is vulnerable to eavesdropping and dictionary attacks; it lacks forward secrecy (an old captured key can decrypt old traffic if reused); TKIP is vulnerable to packet spoofing and decryption attacks; an insecure random number generator (RNG) lets attackers discover the Group Temporal Key (GTK); TKIP flaws can let attackers guess the subnet's IP address.
- **WPA2 issues:** same PSK eavesdropping/dictionary weakness and lack of forward secrecy as WPA; the "Hole196" vulnerability enables MITM and DoS attacks from an already-authenticated insider; insecure RNG can again expose the GTK; the KRACK vulnerability (section 3.25) enables packet sniffing, connection hijacking, malware injection, and decryption through nonce reuse.
- **WPA3 issues:** the stronger algorithms demand more processing power from devices; SAE is vulnerable to timing-based side-channel attacks; it can be vulnerable to cache-based side-channel attacks that leak information from memory access patterns; poor configuration (weak passwords, bad network setup) can still undermine WPA3's protections.

Real-world use: An auditor scanning an office finds a mix of WEP (old printer), WPA (old guest AP), and WPA2 (main staff network). The WEP device is flagged as a critical finding; the WPA device as high; the WPA2 network as acceptable if the passphrase is strong.

EXAM FOCUS: Memorize the IV sizes (24 for WEP, 48 for WPA and WPA2, up to 2^64 for WPA3) and the integrity mechanisms (CRC-32, Michael+CRC- 32, CBC-MAC, BIP-GMAC-256) as a set; the exam often gives one of these values and asks which protocol it belongs to.

> **TRAP:** Do not confuse "Hole196" (a WPA2 insider MITM/DoS flaw) with KRACK (a WPA2 4-way handshake nonce-reuse flaw). Both affect WPA2 but are different vulnerabilities with different root causes.

Memory trick: "24, 48, 48, huge" for IV size growth across WEP, WPA, WPA2, WPA3. "CRC, Michael, CBC-MAC, GMAC" for the integrity upgrade path.

3.10 Wireless Threats

What it is (simple words): The notes group wireless attacks into five threat families based on what the attacker is trying to break: who can join (access control), whether frames are genuine (integrity), whether data stays secret (confidentiality), whether the service stays up (availability), and whether identity can be stolen (authentication).

Access control attacks try to get past WLAN access restrictions, such as AP MAC filters and Wi-Fi port access controls.

- MAC Spoofing (section 3.21)
- AP Misconfiguration: an AP left with weak or default settings
- Ad Hoc Associations: a client connects peer-to-peer, bypassing the AP
- Promiscuous Client: a client that auto-connects to any open AP
- Client Mis-association: a client unintentionally joins a nearby, unauthorized AP with a similar or stronger signal
- Unauthorized Association: a client intentionally joins an attacker's AP

Integrity attacks forge control, management, or data frames to redirect devices into another kind of attack, such as DoS.

- Data Frame Injection, WEP Injection, Bit-Flipping Attacks
- Extensible AP (EAP) Replay, Data Replay, Initialization Vector Replay
- RADIUS Replay, Wireless Network Viruses

Confidentiality attacks try to intercept private data sent over wireless links, whether it was sent in cleartext or encrypted.

- Eavesdropping, Traffic Analysis, Cracking the WEP Key
- Evil Twin AP (section 3.24), Honeypot AP, Session Hijacking

- Masquerading, Man-in-the-Middle Attack (section 3.20)

Availability attacks block legitimate users from reaching WLAN resources, either by crippling resources or by denying access outright.

- Access Point Theft, Denial-of-Service, Authenticate Flood
- Disassociation Attacks, De-authenticate Flood (section 3.19)
- ARP Cache Poisoning Attack (section 3.22), EAP-Failure
- Routing Attacks, Power Saving Attacks, Beacon Flood
- TKIP MIC Exploit

Authentication attacks aim to steal the identity, personal information, or login credentials of Wi-Fi clients to gain unauthorized network access.

- PSK Cracking, Key Reinstallation Attack (KRACK, section 3.25)
- Identity Theft, LEAP Cracking, Shared Key Guessing
- VPN Login Cracking, Domain Login Cracking
- Password Speculation, Application Login Theft

Analogy: Think of a nightclub. Access control attacks sneak past the bouncer's guest list. Integrity attacks forge a VIP wristband. Confidentiality attacks eavesdrop on private conversations inside. Availability attacks jam the entrance so nobody can get in. Authentication attacks steal someone's ID card to get in as them.

EXAM FOCUS: A scenario question will describe an attack and ask which threat family it belongs to. Match the attacker's goal, not the tool: jamming the AP's radio is availability even if the tool used is also capable of other attacks. KRACK is authentication-related because it steals the session key material used in authentication/encryption setup, even though its end effect is reading traffic.

Memory trick: "A-I-C-A-A" in notes order: Access control, Integrity, Confidentiality, Availability, Authentication -> "An Intruder Cannot Avoid Attention."

3.11 Wireless Hacking Methodology

What it is: A five-stage plan for compromising a Wi-Fi network and gaining unauthorized access to its resources. The rest of the module is organized around these five stages.

1. Wi-Fi Discovery
2. Wireless Traffic Analysis
3. Launch of Wireless Attacks
4. Wi-Fi Encryption Cracking
5. Compromise the Wi-Fi Network

Analogy: This is a burglar's plan for a house with a wireless alarm: first find the house and see what alarm it has (discovery), then watch how the alarm signals travel (traffic analysis), then try

specific tricks to disrupt or trick it (attacks), then break its code (encryption cracking), then walk in (compromise).

How it works: Each stage feeds the next. Discovery finds targets and their encryption type. Traffic analysis reveals SSIDs, authentication method, and encryption algorithm in use. Attacks (DoS, MITM, rogue AP) either directly open access or force the handshake needed for cracking. Cracking recovers the key. Compromise means using that key or access to reach the internal network.

Real-world use: A red team is hired to test a retail chain's Wi-Fi. They discover the SSID and BSSID from the parking lot, analyze traffic to confirm WPA2-PSK, de-authenticate a cashier's tablet to force a new handshake, crack the PSK offline with a wordlist, then join the network and pivot to the point-of-sale systems.

Tools and commands used here: Covered in detail per stage in the following sections.

EXAM FOCUS: Memorize the five steps in order; a question may give a description of an action (for example, "capturing a handshake") and ask which stage it belongs to (traffic analysis, or part of launching an attack to force the handshake, depending on phrasing). Read the verb carefully: "capture" leans traffic analysis; "force"/"deauth to capture" leans attack launch.

Memory trick: "D-T-A-E-C": Discovery, Traffic analysis, Attacks, Encryption cracking, Compromise -> "Don't Try Attacking Every Castle."

3.12 Wi-Fi Discovery: Wireless Network Footprinting

What it is (simple words): Before attacking, the attacker must find and footprint the target wireless network, either passively or actively.

Passive footprinting method: the attacker sniffs the airwaves without sending anything. The AP's own beacon/probe-response traffic reveals the AP, its SSID, and any nearby wireless devices that are live.

- Sequence: AP sends a probe response (in reply to other clients, or in its periodic beacon) -> attacker sniffs Wi-Fi traffic -> attacker learns AP and SSID without being detected.

Active footprinting method: the attacker's own wireless device sends a probe request containing an SSID to see if an AP answers; if the device does not know the SSID yet, it sends a probe request with an empty SSID, hoping any AP in range answers.

Analogy: Passive footprinting is listening at a closed door for clues about who's inside. Active footprinting is knocking and asking "is anyone named X home?" which proves you were there.

How it works (numbered steps):

1. Put the wireless card into monitor mode (needed for passive sniffing; see section 3.16 on card selection).
2. Passive: capture beacon and probe-response frames silently.

3. Active: send probe requests (with a known or empty SSID) and record any probe responses.
4. Build a list of nearby SSIDs, BSSIDs, channels, and signal strength.

Real-world use: A penetration tester parked outside an office uses passive footprinting first (nobody notices a laptop just listening), then switches to active probing only once they need to test a specific hidden SSID.

Tools and commands used here: Wi-Fi discovery tools (next section), Aircrack-ng suite's airodump-ng (passive capture).

Countermeasures and defense: Disable unnecessary probe responses, monitor for excessive probe-request traffic, and use a WIPS to flag scanning behavior.

EXAM FOCUS: "An attacker sniffs beacon frames without transmitting anything." -> passive footprinting. "An attacker's device sends probe requests with an empty SSID." -> active footprinting. These mirror the passive/active split from Module 02, but scoped to wireless.

Memory trick: "Passive = Patiently listens. Active = Asks out loud."

3.13 Wi-Fi Discovery: Finding Wi-Fi Networks in Range to Attack

What it is: The attacker's first practical task is to drive or walk around with a laptop running a wireless discovery tool to map every active network in range and pick the best target.

How it works (numbered steps):

1. Enable Wi-Fi on a laptop and install a discovery tool such as inSSIDer or Sparrow-Wifi Analyzer.
2. Drive or walk around the target area while the tool scans.
3. The tool lists each network's MAC address (BSSID), SSID, security type (for example WPA2-Personal), channel, frequency, and signal strength, and plots them on a channel graph.
4. The attacker reviews the list for weak encryption (WEP, open) or interesting SSIDs (a company name) to pick the best target.

Sample fields seen in a Sparrow-Wifi Analyzer-style listing:

```
MAC Address     Security      Channel  Freq   SSID
C8:FA:44:0F:F3:1x PSK TKIP/CCMP  1       2412   -
...           PSK CCMP/TKIP  1       2417   ECC Labs
```

How to read it: "PSK CCMP/TKIP" in the Security column means the AP advertises both WPA2 (CCMP) and WPA/TKIP for backward compatibility, which is weaker than CCMP-only; this is useful intelligence because it tells the attacker a downgrade or TKIP-specific attack may be possible.

Wi-Fi discovery tool list from the notes:

Tool	What it does	Link (as shown)
inSSIDer	Maps active wireless networks while moving	metageek.com
Sparrow-Wifi Analyzer	GUI scanner: security, channel, signal	(open source)
Acrylic Wi-Fi Heatmaps	Wi-Fi heatmap and scanner	acrylicwifi.com
WirelessMon	Wi-Fi monitoring and site survey	passmark.com
Ekahau Wi-Fi Heatmaps	Professional Wi-Fi heatmaps	ekahau.com

> **ADDED CONTEXT:** A "heatmap" tool overlays measured signal strength on a floor plan, helping both attackers (find the strongest signal spot outside a building) and defenders (find dead zones and leakage).

Real-world use: A tester drives around a client's headquarters with inSSIDer and finds the corporate SSID leaking a strong signal into the public parking garage, meaning an attacker never needs to enter the building.

Countermeasures and defense: Tune AP transmit power down so the signal does not leak far outside the building; conduct your own site survey to find and fix overspill.

EXAM FOCUS: "Which type of tool maps Wi-Fi signal strength across a building or outdoor area?" -> a Wi-Fi discovery/heatmap tool such as inSSIDer or Ekahau, not a packet analyzer like Wireshark (that is traffic analysis, section 3.15).

Memory trick: "Discovery tools draw the map; traffic tools read the mail."

3.14 Wi-Fi Discovery: Finding WPS-Enabled APs

What it is (simple words): Wi-Fi Protected Setup (WPS) is a feature that lets a user join a network with an 8-digit PIN or a push-button instead of typing the full passphrase. Attackers use the Wash utility to find WPS-enabled APs and to see if WPS is locked or unlocked.

- **WPS lock:** many routers auto-lock WPS after about five failed PIN attempts; it can usually only be unlocked from the router's admin interface, which slows (but does not always stop) brute-force attacks.

How it works (numbered steps):

1. Put the wireless interface into monitor mode (airmon-ng).
2. Run Wash against the monitor interface to list nearby APs with WPS enabled, their BSSID, ESSID, channel, signal (dBm), and lock state.
3. Wash can also scan the 5 GHz band, not just 2.4 GHz.
4. The attacker picks an unlocked WPS AP as a target for Reaver (section 3.34).

Command shown in the notes:

```
sudo wash -i wlan0
```

- `wash`: the WPS-scanning utility (part of the Reaver project).
- `-i wlan0`: use interface wlan0 (in the notes, the live demo used the interface name wlx00e02d886189, a typical Linux USB-adapter name).

Sample output fields: BSSID, Ch (channel), dBm (signal strength), WPS (version), Lck (locked yes/no), Vendor, ESSID.

Real-world use: A tester runs Wash in a coffee shop's parking lot and finds the shop's router advertises WPS and is unlocked. This router becomes the Reaver target to recover the WPA2 passphrase without touching the passphrase directly.

Tools and commands used here: wash, airmon-ng (section 3.17).

Countermeasures and defense: Disable WPS entirely on routers that support it; if WPS must stay on, rely on its lockout behavior and monitor for repeated authentication failures.

EXAM FOCUS: "Which tool identifies WPS-enabled APs and their lock state?" -> Wash. Trap: Wash only finds and reports WPS APs; it does not crack the PIN itself (that is Reaver's job).

Memory trick: "Wash finds the door, Reaver picks the lock."

3.15 Wireless Traffic Analysis

What it is (simple words): Once an AP is found, the attacker captures and studies its traffic to learn the broadcast SSID, whether multiple APs exist, whether a hidden SSID can be recovered, the authentication method, and the WLAN encryption algorithm in use.

How it works (numbered steps):

1. Put the card into monitor mode.
2. Start a Wi-Fi packet analyzer (Wireshark, AirMagnet, OmniPeek, CommView for Wi-Fi) on the monitor interface.
3. Filter and inspect 802.11 management frames: beacon frames, probe responses, and association/authentication frames.
4. Read the frame details: SSID, BSSID, encryption/cipher suite, sequence numbers, and signal/timing fields.

Sample Wireshark capture fields from the notes:

```
No. Time       Source  Destination Protocol Info
646 16.177 ...  TP      Broadcast   802.11   Beacon frame, SN=1118
647 16.191 ...  zt      IntelCor... 802.11   Probe Response, SN=231
```

How to read it: every "Beacon frame" row is the AP announcing itself to everyone (Destination = Broadcast); every "Probe Response" row is the AP answering one specific client's probe request (Destination = a unicast MAC). The Info column's "BI=100" means Beacon Interval of 100 time units (about 100 ms), a normal default.

Wi-Fi packet analyzer tools from the notes:

Tool	Platform/notes
Wireshark	Free, cross-platform, the de facto standard
AirMagnet WiFi Analyzer Pro	Commercial, enterprise Wi-Fi analysis
OmniPeek	Commercial packet analyzer
CommView for Wi-Fi	Commercial, Windows Wi-Fi sniffer

Real-world use: A tester captures beacon frames and notices one AP answers probe requests for SSID "Guest" while hiding its real SSID from beacons; this confirms the real network uses hidden-SSID (SSID cloaking) and that the "Guest" SSID is a decoy or a separate network.

Countermeasures and defense: Treat SSID cloaking as weak defense only (it is defeated by sniffing probe responses or by the mdk3 technique in section 3.18); rely on strong encryption instead.

EXAM FOCUS: "Which tool is the open-source standard for 802.11 packet capture and analysis?" -> Wireshark. Trap: a question describing "analyzing broadcast SSID, encryption algorithm, and authentication method" is traffic analysis (stage 2), not discovery (stage 1), even though both use similar sniffing skills.

Memory trick: "Discovery finds the AP's name tag; traffic analysis reads the AP's diary."

3.16 Choosing the Optimal Wi-Fi Card

What it is (simple words): Not every Wi-Fi adapter can do what an attacker needs (monitor mode and packet injection). Picking the right card and chipset is a prerequisite for tools such as Aircrack-ng and KisMAC, which only support certain chipsets.

Factors to consider when choosing a Wi-Fi card (numbered list):

1. Determine the Wi-Fi requirements (bands, monitor mode, injection).
2. Learn the capabilities of a wireless card (supported standards).
3. Determine the chipset of the Wi-Fi card.
4. Verify the chipset capabilities (does it support monitor mode and packet injection?).
5. Determine the drivers and patches required (some chipsets need a patched driver to unlock monitor/injection mode).

Analogy: Not every camera can shoot in low light. A photographer checks the sensor (chipset) and lens (driver support) before buying, the same way a wireless tester checks chipset and driver support before buying an adapter.

Real-world use: A student buys a cheap USB Wi-Fi adapter for a CEH lab, only to find Aircrack-ng cannot put it into monitor mode because its chipset lacks Linux driver support for injection; they return it and buy an Atheros or Ralink chipset adapter instead (both are commonly supported).

Tools and commands used here: Aircrack-ng, KisMAC (only work with selected chipsets).

EXAM FOCUS: "Why would an attacker research a Wi-Fi card's chipset before buying it?" -> to confirm it supports monitor mode and packet injection, which tools like Aircrack-ng require.

Memory trick: "No injection, no Aircrack action."

3.17 Launch of Wireless Attacks: Aircrack-ng Suite

What it is (simple words): Aircrack-ng is a complete suite for 802.11 wireless security work: detecting networks, sniffing packets, and cracking WEP and WPA/WPA2-PSK keys. It runs on Linux and Windows.

Tools in the Aircrack-ng suite:

Tool	What it does
airmon-ng	Enables/disables monitor mode on a wireless card
airodump-ng	Captures raw 802.11 frames, collects WEP IVs
aireplay-ng	Injects frames; gathers WEP IVs and WPA handshakes
aircrack-ng	De facto WEP and WPA/WPA2-PSK cracking tool
airdecap-ng	Decrypts WEP/WPA/WPA2 captures, strips headers
airdrop-ng	Targeted, rule-based de-authentication of users
airolib-ng	Stores/manages ESSID and password lists for cracking
airbase-ng	Captures WPA/WPA2 handshakes; can act as an ad-hoc AP

> **ADDED CONTEXT:** airbase-ng is the tool most often used to build a simple rogue/fake AP for capturing handshakes or running MITM-style setups, complementing the MANA Toolkit covered in section 3.23.

Analogy: Aircrack-ng is a Swiss Army knife for Wi-Fi attacks: each blade (sub-tool) has one job, and the whole knife folds into a single workflow: set monitor mode, capture, inject, crack.

Real-world use: Across sections 3.18 to 3.34, nearly every live demo in this module (hidden SSID detection, DoS, MITM, WPA/WPA2 and WPA3 cracking) uses two or more of these tools chained together.

Official source: https://www.aircrack-ng.org

EXAM FOCUS: This tool table is a favorite exam target. Learn to match a one-line description to the exact sub-tool name; for example, "stores ESSID and password lists" is airolib-ng, not aircrack-ng itself.

> **TRAP:** airdrop-ng (targeted deauth) and aireplay-ng (general injection, including deauth) sound similar. airdrop-ng applies rule-based filtering to decide which clients to deauth; aireplay-ng is the general-purpose injection tool used directly with --deauth.

Memory trick: "Mon-Dump-Replay-Crack-Decap-Drop-Olib-Base" in rough workflow order: Monitor mode, Dump packets, Replay/inject, Crack the key, Decap (decrypt), Drop (targeted deauth), Olib (password store), Base (fake AP).

3.18 Launch of Wireless Attacks: Detection of Hidden SSIDs

What it is (simple words): A hidden SSID (one that is not broadcast in beacon frames) is not truly secret. The AP still reveals it in other frames, or an attacker can brute-force it with a tool such as mdk3/mdk4.

How it works (numbered steps, from the notes' three-step demo):

Step 1 - Enable monitor mode:

```
airmon-ng start wlx00e02d886189
```

Step 2 - Discover SSIDs on the interface:

```
airodump-ng wlx00e02d886189
```

The output lists BSSID, power (PWR), beacons, data count, channel (CH), encryption (ENC), cipher, authentication (AUTH), and ESSID. A hidden network shows `ESSID: <length: 0>` because no SSID was seen in its beacons yet.

Step 3 - Brute force the hidden SSID with mdk3:

```
mdk3 wlx00e02d886189 p -b 1 -c 2 -t 1C:3B:F3:40:10:74
```

Flag breakdown: `p` runs the probing/SSID-bruteforce mode; `-b 1` sets a bruteforce character set option; `-c 2` sets the channel to 2; `-t <BSSID>` targets the specific AP.

Sample output read-through:

```
SSID Bruteforce Mode activated!
channel set to: 2
All 26 possible SSIDs with length 1 sent, trying length 2.
Got response from 1C:3B:F3:40:10:74, SSID: "ECC Labs"
```

How to read it: mdk3 tries every possible SSID string, starting at length 1, then 2, then 3, and so on, sending probe requests for each guess. When the real AP replies to one specific guess, that guess is the true hidden SSID, here "ECC Labs" (plus some other examples hinted at in the capture, partly cut off in the source screenshots [UNCLEAR on page 11]).

Real-world use: A company hides its SSID thinking it adds security. A tester recovers the real SSID in under a minute using mdk3, proving hidden SSID is not a real control.

Tools and commands used here: airmon-ng, airodump-ng, mdk3 (also known as mdk4 in newer distributions).

Countermeasures and defense: Do not rely on SSID hiding as a security control; use it only as a very minor obscurity layer on top of strong encryption and access control.

EXAM FOCUS: "Is hiding the SSID an effective security control?" -> No, it only slightly raises the bar; it can be defeated by sniffing probe responses or brute-forcing with mdk3. Flag recall: know that `-t` targets a BSSID and `-c` sets the channel in this mdk3 command.

Memory trick: "Hidden is not Hidden: mdk3 tries every name until the AP answers."

3.19 Launch of Wireless Attacks: Denial-of-Service (Disassociation and De-authentication)

What it is (simple words): Both attacks force one client offline by abusing unauthenticated 802.11 management frames, but they target different connection states.

Disassociation attack:

1. The client is authenticated AND associated with the AP (fully connected, normal state).
2. The attacker sends a forged disassociate request to take the client offline.
3. Result: the client is still authenticated but no longer associated. It can often re-associate quickly without a fresh authentication.

De-authentication attack:

1. The client is fully connected (authenticated and associated).
2. The attacker sends a forged de-authenticate request.
3. Result: the client is no longer authenticated OR associated. It must start the connection process over from authentication.

Analogy: Disassociation is like being told to step out of the meeting room for a moment, you are still an employee (authenticated) and can walk back in. De-authentication is like having your badge (authentication) revoked entirely; you must sign in again from the front desk.

Command shown in the notes:

```
aireplay-ng --deauth 25 -h <TARGET_MAC> -b <AP_MAC> ath1
```

Flag breakdown:

Flag	Meaning
--deauth 25	Send 25 de-authentication packets
-h TARGET_MAC	Spoofed source: the target client's MAC
-b AP_MAC	BSSID: the access point being impersonated
ath1	The monitor-mode wireless interface to use

Real-world use: A tester needs a fresh WPA2 handshake to crack offline. They run a short de-authentication burst against one known client, forcing it to reconnect, and airodump-ng captures the resulting 4-way handshake (feeding section 3.30).

Tools and commands used here: aireplay-ng (--deauth), airdrop-ng (rule-based targeted version).

Countermeasures and defense: Use 802.11w (Management Frame Protection) to require signed deauth/disassociation frames; monitor for bursts of deauth frames with a WIPS.

EXAM FOCUS: "A client is kicked offline but reconnects instantly without a new login screen." -> likely disassociation. "A client is fully kicked off and must authenticate again from scratch." -> de- authentication. Both are management-frame attacks, both are commonly run with aireplay-ng --deauth in practice.

Memory trick: "Disassociate = Demoted. De-authenticate = Deleted."

3.20 Launch of Wireless Attacks: Man-in-the-Middle Attack

What it is (simple words): The attacker positions themselves between the victim and the real AP, so all traffic flows through the attacker, who can read, modify, or drop it.

How it works (numbered steps, from the MITM diagram):

1. Attacker sniffs the victim's wireless parameters: MAC address, ESSID/BSSID, and number of channels in use.
2. Attacker sends a de-authentication request to the victim, spoofing the source address of the victim's real AP.
3. The victim is deauthenticated and starts scanning all channels for a new valid AP to join.
4. Attacker sets up a forged AP on a new channel using the original AP's MAC address (BSSID) and ESSID.
5. The victim connects to the forged AP, believing it is the real one.

6. After the victim successfully associates with the forged AP, the attacker in turn connects to the real AP, pretending to be the victim.
7. The attacker now sits in between the real AP and the victim and listens to all the traffic passing both ways.

MITM using Aircrack-ng (numbered steps from the notes' demo):

1. Enable monitor mode: `airmon-ng start eth1`
2. Capture and save IVs: `airodump-ng --ivs -write capture eth1`, which lists each AP's BSSID, power, beacons, data rate, channel, cipher, authentication, and ESSID, plus associated stations.
3. De-authenticate the real client: `aireplay-ng -0 5 -a 02:24:2B:CD:68:EE eth1` (`-0 5` sends 5 deauth bursts; `-a` is the target AP's BSSID).
4. Fake-associate the attacker's own card with the target AP:

```
aireplay-ng -1 0 -e SECRET_SSID -a 1e:64:51:3b:ff:3e \
  -h 02:24:2B:CD:68:EE eth1
```

Flag breakdown: `-1 0` runs fake authentication with 0 reassociation delay; `-e` names the target ESSID; `-a` is the AP's BSSID; `-h` is the attacker's spoofed source MAC.

Sample output read-through:

```
22:25:10  Sending Authentication Request
22:25:10  Authentication successful
22:25:10  Sending Association Request
22:25:10  Association successful :-)
```

How to read it: each line is a stage of 802.11 open-system authentication and association completing successfully; "Association successful" confirms the attacker's card is now a recognized client of the target AP, which is the foothold step before further MITM or injection work.

Real-world use: A tester proves to a client that an attacker in the parking lot can silently intercept employee web traffic by forcing a fake-AP MITM, then shows captured plaintext HTTP credentials as evidence.

Tools and commands used here: airmon-ng, airodump-ng, aireplay-ng.

Countermeasures and defense: Use mutual authentication (WPA2/WPA3- Enterprise with certificate validation) so a client can verify it is really the authorized AP; enable 802.11w; use a VPN over wireless so even a successful MITM only sees encrypted traffic.

EXAM FOCUS: "Which attack forces a client off its real AP and onto a forged one with the same BSSID/ESSID, so the attacker can read all traffic?" -> Man-in-the-Middle (via deauth + fake AP). Flag recall: know that aireplay-ng's `-0` mode is deauth, `-1` mode is fake authentication.

Memory trick: "Deauth, Forge, Reconnect, Relay: the 4-step MITM loop."

3.21 Launch of Wireless Attacks: MAC Spoofing Attack

What it is (simple words): MAC spoofing changes a network card's reported Media Access Control (MAC) address to match an authorized user's MAC, bypassing MAC-address filtering on an AP.

- **MAC filtering:** an AP setting that only allows devices whose MAC address is on an approved list to connect.

Analogy: MAC filtering is like a guest list checked by name badge. MAC spoofing is printing a fake badge with an approved guest's name on it.

How it works (Linux, numbered steps, ifconfig method):

```
ifconfig wlan0 down
ifconfig wlan0 hw ether 02:25:ab:4c:2a:bc
ifconfig wlan0 up
```

1. `ifconfig wlan0 down`: log in as root and disable the interface (a MAC address can only be changed while the interface is down).
2. `ifconfig wlan0 hw ether 02:25:ab:4c:2a:bc`: set the new MAC address in aa:bb:cc:dd:ee:ff hex format.
3. `ifconfig wlan0 up`: bring the interface back up with the new MAC.

Modern equivalent using `ip` (the notes also show this, since ifconfig is deprecated on many distributions):

```
ip link show
ip link set dev eth0 down
ip link set dev eth0 address 00:11:22:33:44:55
ip link set dev eth0 up
ip link show eth0
```

> **ADDED CONTEXT:** `ifconfig` comes from the older net-tools package and is deprecated on modern Linux; `ip link` (from iproute2) is the current standard. The exam may show either; know that both achieve the same MAC-change result.

GUI tools from the notes:

Tool	Platform	Notes
Technitium MAC Address Changer	Windows	Instant MAC spoofing GUI
LizardSystems Change MAC Address	Windows	Similar MAC spoofing GUI

Real-world use: An attacker captures the MAC address of an authorized laptop by sniffing traffic, then spoofs that MAC on their own adapter to bypass a coffee shop's MAC-filtered guest Wi-Fi.

Tools and commands used here: ifconfig, ip link, Technitium MAC Address Changer.

Countermeasures and defense: Treat MAC filtering as a weak, easily bypassed control; pair it with real authentication (WPA2/WPA3 with a strong key or 802.1X); monitor for MAC address conflicts (the same MAC appearing from two locations at once) as a spoofing indicator.

EXAM FOCUS: "Why is MAC filtering alone considered weak?" -> MAC addresses are visible in cleartext on the air (even on encrypted networks, frame headers are not encrypted) and are trivially changed in software. Command recall: know that the interface must be brought down before changing its MAC address with ifconfig.

Memory trick: "MAC filtering checks the name tag; spoofing just prints a new one."

3.22 Launch of Wireless Attacks: Wireless ARP Poisoning Attack

What it is (simple words): ARP poisoning on a wireless network tricks the network's routers and switches into sending a victim's traffic to the attacker instead of the correct destination, by lying about which MAC address owns an IP address.

How it works (numbered steps, from the diagram):

1. The attacker spoofs the MAC address of the victim's wireless laptop (for example "Jessica's" laptop) and authenticates to AP1 using that spoofed MAC.
2. AP1 sends updated MAC address information to the network's routers and switches, which update their routing and switching (ARP/MAC address) tables to point to AP1 for that MAC.
3. Traffic that was destined from the network backbone to the victim's system (previously reachable through AP2) is no longer sent to AP2; it is now redirected toward the attacker's position at AP1.

- **ARP (Address Resolution Protocol):** maps an IP address to a MAC address on a local network; it has no built-in authentication, so false ARP replies are accepted at face value, which is the root cause of ARP poisoning.

Analogy: ARP poisoning is like telling the post office that your neighbor's mailbox is now located at your house; all their mail starts arriving at your door instead.

ARP poisoning using Ettercap (numbered steps from the notes):

1. Launch Ettercap and select Sniff -> Unified Sniffing.
2. In the setup pop-up, set the Primary interface to sniff and click OK.
3. Select Hosts -> Scan for Hosts; Ettercap scans and lists live hosts.
4. Select Hosts -> Hosts List to view discovered hosts (IP, MAC, description).
5. Select View -> Connections to start watching identified connections.
6. In the Hosts window, select a target IP, then Targets -> Current Targets to add it to the target list.
7. Go to the MITM menu, select MITM -> ARP Poisoning; in the pop-up, select "Sniff remote connections" and click OK to launch the attack.

Real-world use: A tester uses Ettercap on an open guest Wi-Fi to redirect a target laptop's traffic through their own machine, then captures unencrypted HTTP sessions as proof of risk.

Tools and commands used here: arpspoof, Ettercap.

Countermeasures and defense: Use dynamic ARP inspection on managed switches where available; use static ARP entries for critical hosts; encrypt traffic end to end (HTTPS, VPN) so a successful ARP poisoning attack cannot read the content.

EXAM FOCUS: "Which protocol's lack of authentication is exploited in ARP poisoning?" -> ARP itself (no authentication of replies). "Which tool provides a GUI workflow for ARP poisoning and sniffing?" -> Ettercap.

Memory trick: "ARP poisoning: lie about the address, steal the mail."

3.23 Launch of Wireless Attacks: Rogue Access Points

What it is (simple words): A rogue AP is any unauthorized access point that provides backdoor access into a target wireless network, whether planted by an attacker or set up carelessly by an employee.

Scenarios for rogue AP installation (from the notes):

- A compact, pocket-sized rogue AP device plugged into an Ethernet port of a corporate network.
- A rogue AP device connected to the corporate network over a Wi-Fi link.
- A USB-based rogue AP device plugged into a corporate machine.
- A software-based rogue AP running on a corporate Windows machine.

Steps to deploy a rogue AP:

1. Choose a location that gives maximum coverage from the connection point.
2. Disable SSID broadcast (silent mode) and management features to avoid detection.
3. Place the AP behind a firewall, if possible, to avoid network scanners.
4. Deploy the rogue AP for only a short period to reduce detection risk.

Creating a rogue AP with the MANA Toolkit (numbered steps):

1. Edit `hostapd-mana.conf` (MANA's configuration file) to set up the fake AP's interface, BSSID, and SSID.
2. Edit `start-nat-simple.sh`, the script that launches the rogue AP with NAT so clients get real internet access.
3. Run the script: `bash /usr/share/mana-toolkit/run-mana/start-nat-simple.sh`
4. Once the rogue AP is up, connect to it from a different device using a different wireless card.
5. On that Wi-Fi-enabled device, look for an unprotected internet connection and connect.
6. All data packets from the victim's machine now flow through the rogue AP; the attacker uses tools such as tcpdump and Wireshark to capture and analyze them.

Sample configuration fields seen in the notes:

```
interface=wlan0
bssid=00:11:22:33:44:00
ssid=Free Internet
channel=6
```

Sample console output:

```
Using interface wlan0 with hwaddr 00:11:22:33:44:00
wlan0: interface state UNINITIALIZED -> ENABLED
wlan0: AP-ENABLED
MANA - Directed probe request for SSID 'Troy' from 54:...
```

How to read it: "Directed probe request for SSID 'Troy'" shows MANA is responding to real client devices that are actively probing for a previously-remembered network named "Troy", a sign MANA is acting as a "karma"-style AP that answers for any SSID a client asks about (see section 3.28 for the related Karma attack).

Real-world use: An attacker leaves a small rogue AP plugged into an open Ethernet jack in a conference room, labeled "Free Internet"; staff connect, unaware their traffic is now passing through the attacker's box.

Tools and commands used here: MANA Toolkit (hostapd-mana), tcpdump, Wireshark.

Countermeasures and defense: See section 3.36 (detection and blocking of rogue APs) for RF scanning, AP scanning, and wired-side detection methods.

EXAM FOCUS: "What distinguishes a rogue AP from an Evil Twin?" -> a rogue AP is simply unauthorized (it may use any SSID, even an obvious one like "Free Internet"); an Evil Twin specifically impersonates a legitimate, trusted SSID to trick users (section 3.24). All Evil Twins are rogue APs, but not all rogue APs are Evil Twins.

Memory trick: "Rogue = unwanted guest. Evil Twin = unwanted guest wearing your sibling's face."

3.24 Launch of Wireless Attacks: Evil Twin

What it is (simple words): An Evil Twin is a wireless AP that pretends to be a legitimate, trusted AP by copying its network name (SSID), tricking users into connecting to the attacker instead.

How it works:

1. The attacker learns a trusted SSID (for example a coffee shop's "STARBUCKS" Wi-Fi, or a company's WLAN SSID).
2. The attacker sets up a rogue AP outside the corporate or public perimeter using that same SSID.
3. Users nearby see a familiar, trusted network name and connect without suspicion.

4. Once associated, users may unknowingly bypass enterprise security policies, giving the attacker access to their data.

Analogy: An Evil Twin is a fake taxi with the same company logo and colors as the real one, parked right next to the real taxi stand; passengers get in without checking, assuming it is legitimate.

Real-world use: Employees take laptops to Starbucks, FedEx Office, or the airport, all places with common, trusted public Wi-Fi SSIDs. An attacker sets up an Evil Twin using the same SSID in the same location, and some employee devices auto-join it because they have joined that SSID name before. The exam notes frame this exact scenario as the business risk: "how do you keep company data safe" when staff roam.

Tools and commands used here: airbase-ng, MANA Toolkit, hostapd.

Countermeasures and defense: Train users not to trust open public SSIDs by name alone; use a VPN for all traffic on public Wi-Fi; prefer WPA2/WPA3-Enterprise with certificate-based mutual authentication, which an Evil Twin cannot forge without the real certificate.

EXAM FOCUS: "An attacker clones a known SSID to lure victims." -> Evil Twin. Keyword: "common residential SSID, hotspot SSID, or company's WLAN SSID" being copied is the giveaway for Evil Twin, compared to a generic rogue AP which does not need to copy anything.

Memory trick: "Evil Twin: same name, same face, different owner."

3.25 Launch of Wireless Attacks: Key Reinstallation Attack (KRACK)

What it is (simple words): KRACK exploits a flaw in how the WPA2 4-way handshake installs its encryption key, forcing the victim's device to reuse a cryptographic nonce value that should only ever be used once. This lets the attacker decrypt and read traffic.

- **Nonce:** a "number used once" in a cryptographic exchange; reusing a nonce with the same key breaks the security guarantees of the cipher.
- **4-way handshake:** the process every secure Wi-Fi network uses to join and generate a fresh encryption key for that session.

The WPA2 4-way handshake (normal, numbered steps):

1. Message 1: AP sends ANonce (AP's nonce) to the client.
2. Message 2: client sends back a signed SNonce (client's nonce).
3. Message 3: AP sends a signed ANonce and triggers encryption key installation on the client.
4. Message 4: client sends an acknowledgement; both sides now use the fresh session key.

The KRACK attack on the handshake (numbered steps):

1. The attacker intercepts the traffic between the client and AP (positioned as a cloned/rogue access point in the middle).
2. The attacker replays Message 3 of the handshake to the client.

3. The client, upon receiving the replayed Message 3, reinstalls the same encryption key and resets its nonce/packet counters, even though it already installed that key once.
4. Because the key and nonce sequence are now reused, the attacker can decrypt packets the victim sends, or in some variants, inject forged packets.

> **ADDED CONTEXT:** KRACK (Key Reinstallation Attack) was disclosed by researcher Mathy Vanhoef in 2017. It affects the WPA2 handshake implementation, not the AES-CCMP cipher itself, which is why a firmware/driver patch (fixing nonce reuse handling), not a new cipher, was the fix most vendors shipped.

WPA2 4-way handshake authentication options (from the notes):

Mode	Authentication method	Fit
WPA2-Personal (PSK)	Shared password	Home, small business
WPA2-Enterprise (802.1X)	RADIUS server	Enterprise networks

KRACK can affect both modes because the flaw is in the handshake mechanics, not in how the initial password or RADIUS credentials are verified.

Real-world use: Before patches were widely deployed, an attacker near a WPA2-protected office could clone the AP, force handshake replay, and silently read credit card numbers, passwords, chat messages, emails, and photos passing over what the victim believed was a secure connection.

Tools and commands used here: Custom KRACK proof-of-concept tools (not named individually in the notes); conceptually chained with a cloned/rogue AP similar to section 3.20's MITM setup.

Countermeasures and defense: Apply vendor patches to both APs and client devices (the fix must handle nonce reuse correctly on reinstall); prefer WPA3, whose SAE handshake design is not vulnerable to this specific nonce-reuse flaw.

EXAM FOCUS: "Which WPA2 message does KRACK replay to force nonce reuse?" -> Message 3 of the 4-way handshake. Trap: KRACK is a flaw in protocol/implementation logic, not a weakness in AES itself; do not answer "AES is broken" on a KRACK question.

Memory trick: "KRACK: resend Message 3, recycle the nonce, read the traffic."

3.26 Launch of Wireless Attacks: Jamming Signal Attack

What it is (simple words): Jamming floods the radio spectrum with noise so legitimate Wi-Fi devices cannot communicate, causing a Denial of Service.

- **CSMA/CA (Carrier Sense Multiple Access with Collision Avoidance):** the access method 802.11 uses; a radio must sense a period of silence before it is allowed to transmit. A jamming signal denies that silence, so no legitimate radio ever gets a turn to transmit.

How it works:

1. The attacker places a high-gain amplifier/jamming device near the target area.
2. The jammer continuously transmits noise (for example on 2.4 GHz) at high power.
3. Legitimate radios, following CSMA/CA, keep waiting for silence that never comes, or their packets collide with the jamming signal.
4. Users cannot log in, or existing connections are knocked offline by the overpowering nearby signal.

Analogy: Jamming is like one person shouting nonstop in a room where people are supposed to take turns speaking; nobody else can get a word in.

Wi-Fi jamming devices listed in the notes (illustrative hardware specs; treat exact figures as vendor marketing, verify if needed):

Model	Range	Antennas	Bands jammed
PCB-4510	50-150 m	10	GSM, 3G, UMTS, 4G, Wi-Fi, GPS, 5G
CPB-2920	10-40 m	20	CDMA, DCS, PCS, 3G, UMTS, 4G, 5G
CPB-2612H-5G	20-60 m	12	5G, 4G, GSM, 3G, UMTS, Wi-Fi, UHF/VHF
CPB-2080-5G	10-40 m	8	5G, 4G LTE, 3G, UMTS, Wi-Fi
PCB-2112	20-50 m	12	CDMA, DCS, 3G, Wi-Fi, 4G LTE, 5G, GPS
PCB-1016	10-30 m	16	CDMA, DCS, 3G, 4G, Wi-Fi, GPS, 5G

Real-world use: A physical penetration test includes a brief, authorized jamming test to prove that a building's wireless security cameras drop offline under RF interference, a finding that pushes the client to add a wired backup link for critical cameras.

> **ADDED CONTEXT:** Operating a jamming device against real-world networks without authorization is illegal in most countries (for example, prohibited by the FCC in the United States, verify local law). On the exam, jamming is tested as a concept and as a DoS category, not as a "go buy a jammer" tool recommendation.

Countermeasures and defense: Use spectrum analyzers to detect jamming sources; have a wired backup for critical systems; in licensed and lawful contexts, use frequency-hopping or directional antennas to reduce jamming impact.

EXAM FOCUS: "Why does jamming cause a DoS on 802.11 specifically?" -> because CSMA/CA requires a period of silence before any radio may transmit, and jamming denies that silence to everyone.

Memory trick: "Jamming: shout over everyone, nobody gets to talk."

3.27 Launch of Wireless Attacks: aLTEr Attack

What it is (simple words): The aLTEr attack targets LTE (4G) mobile networks, not Wi-Fi directly. The attacker installs a fake communication tower between a real phone and the real cell tower, then uses that position to redirect the user to a malicious website.

How it works in two phases:

Information gathering phase:

1. The attacker passively collects information needed to perform the attack using techniques such as identity mapping and website fingerprinting of the victim's normal traffic patterns.

Attack phase:

1. The attacker places a fake base tower between the victim's LTE device and the real base tower.
2. The victim's valid requests are intercepted by the fake tower.
3. The attacker performs DNS spoofing, swapping a legitimate domain's answer for a malicious IP.
4. The victim's browser is redirected to a malicious website with a misleading web address, while believing it reached the intended site.
5. The attacker monitors user traffic and stores user credentials entered on the fake/malicious site.
6. The spoofed DNS response ultimately still allows the malicious request to also reach the real/original server where relevant, to keep the deception convincing.

Analogy: aLTEr is like a fake relay tower that quietly swaps road signs along a highway, routing drivers (data) into a fake rest stop (malicious website) that looks just like the real one.

Real-world use: A researcher demonstrates aLTEr in a lab to show that even LTE's encryption does not stop DNS-level redirection attacks when an attacker controls a fake tower in range, pushing carriers toward better integrity protection in later cellular standards.

Countermeasures and defense:

- Encrypt DNS queries and use trusted DNS resolvers only.
- Resolve DNS over HTTPS (DoH).
- Use DNS over TLS (DoT) or DTLS for encryption and integrity protection of DNS traffic.
- Implement RFC 7858 / RFC 8310 to prevent DNS spoofing.
- Use the DNSCrypt protocol to authenticate client-resolver communication.

- Use strong end-to-end encryption such as AES-256 for all communications.
- Use mutual authentication to verify both communicating parties' identities.

EXAM FOCUS: "Which network type does the aLTEr attack target?" -> LTE (4G) mobile/cellular networks, using DNS spoofing as the active technique. This is a rare topic the exam may test with a single definition-style question; know it targets LTE, not Wi-Fi, and know the DNS-related countermeasures (DoH, DoT, DNSCrypt, RFC 7858/8310).

Memory trick: "aLTEr alters your DNS answer through a fake LTE tower."

3.28 Launch of Wireless Attacks: Wi-Jacking Attack

What it is (simple words): Wi-Jacking is a multi-step attack chain that disconnects a victim from their real Wi-Fi, lures them to a malicious network, injects a malicious URL, and ultimately steals the victim's own router admin credentials and WPA2 PSK.

How it works (numbered steps):

1. Send deauthentication requests to the victim's device (using aireplay-ng) to disconnect them from their legitimate Wi-Fi network.
2. Perform a Karma attack using hostapd-wpe, luring the victim to connect to a malicious Wi-Fi network that answers to any SSID the victim's device remembers.
3. Use tools such as dnsmasq and Python scripts to inject a malicious URL, luring the victim's browser to load it.
4. Wait for the victim to access an HTTP page; at this point, the victim's router is tricked into updating and restarting automatically.
5. When the victim opens the malicious page, their browser automatically loads stored credentials from the router (because the page runs in the context of the router's own admin interface origin).
6. Stop the Karma attack and let the victim reconnect to their legitimate network; the malicious page remains cached in the router's admin interface origin, along with admin credentials loaded into JavaScript.
7. Use XMLHttpRequest to log in to the router and extract the victim's WPA2 PSK, then make any other required malicious changes.

- **Karma attack:** a rogue AP technique where the fake AP automatically answers "yes" to any SSID a nearby device probes for, since devices often probe for every network they have joined before.

Command shown in the notes:

```
aireplay-ng -0 11 -a 22:7F:AC:6D:E6:8B \
  -c EE:AB:46:A7:CF:18 wlx00e02d886189
```

Flag breakdown: `-0 11` sends 11 deauth bursts; `-a` is the target AP's BSSID; `-c` is the target client's MAC.

Sample output read-through:

```
07:27:51  Sending 64 directed DeAuth (code 7).
        STMAC: [EE:AB:46:A7:CF:18] [0|62 ACKs]
```

How to read it: "code 7" is the 802.11 reason code for a deauth frame (class 3 frame received from a nonassociated station); "STMAC" is the target station's MAC; "[0|62 ACKs]" shows how many of the injected frames were acknowledged, a rough signal of injection success.

Real-world use: An attacker at a cafe runs the full Wi-Jacking chain against a customer's phone, ultimately extracting the customer's home router's WPA2 PSK and admin password once the phone automatically reconnects home and the cached malicious page fires its credential-stealing script.

Tools and commands used here: aireplay-ng, hostapd-wpe, dnsmasq, Python scripts, XMLHttpRequest (JavaScript).

Countermeasures and defense: Disable router auto-restart/auto- update triggers from unauthenticated HTTP pages; use HTTPS-only router admin interfaces; change default router admin credentials; keep router firmware updated.

EXAM FOCUS: "Which multi-step attack combines deauth, a Karma rogue AP, and malicious URL injection to steal a router's own admin credentials and WPA2 PSK?" -> Wi-Jacking. Trap: do not confuse Wi- Jacking (steals the router's own credentials via a cached malicious page) with a simple Evil Twin (only harvests whatever the user types on the fake portal).

Memory trick: "Wi-Jacking: Deauth, Karma, Inject, Wait, Steal the router's own keys."

3.29 Launch of Wireless Attacks: RFID Cloning Attack

What it is (simple words): RFID cloning captures the data stored on a legitimate RFID (Radio Frequency Identification) tag or card, then writes that same data onto a new blank chip, creating a working duplicate.

- **RFID tag:** a small chip with an antenna that stores data and answers a reader's radio signal; used in access badges, key fobs, and transit cards.

How it works:

1. The attacker brings an RFID reader/cloning device near the target tag or card (often without the owner noticing, if close enough).
2. The device reads and stores the tag's data.
3. The attacker writes that captured data onto a blank RFID chip.
4. The cloned chip now behaves identically to the original at any reader that accepts it, such as a building's door access system.

RFID cloning tools from the notes:

Tool	Notes
iCopy-X	Stand-alone, portable RFID cloning device
RFIDler	Open-source RFID tool, github.com
RFID Mifare Cloner	Clones Mifare-family cards, github.com
Flipper Zero	Multi-tool including RFID read/clone, flipperzero.one
Boscloner Pro	Dedicated RFID cloning hardware, boscloner.com

Analogy: RFID cloning is like photocopying a hotel keycard; the copy opens the same doors as the original, and the hotel's lock has no way to tell the two apart.

Real-world use: During a physical penetration test, a tester walks close to an employee in a crowded lobby, clones their badge with a pocketable reader like iCopy-X, then uses the clone to open a "staff only" door later that day.

Countermeasures and defense: Use RFID cards with cryptographic challenge-response (not simple static-ID cards, which are trivial to clone); use RFID-blocking sleeves for badges; monitor for duplicate badge use (same badge ID used at two far-apart doors close in time).

EXAM FOCUS: "Which attack duplicates a physical access badge by copying its stored data onto a blank chip?" -> RFID cloning. This is grouped under wireless attacks because RFID is a short-range wireless technology, even though it is not Wi-Fi.

Memory trick: "RFID cloning: read the badge, write the badge, walk in."

3.30 Wi-Fi Encryption Cracking: WPA/WPA2

What it is (simple words): WPA/WPA2-PSK uses a user-defined password to build the TKIP or CCMP session keys. The per-packet key itself is not directly crackable, but the original password can be recovered offline through a dictionary (wordlist) attack against a captured handshake.

Key concepts from the notes:

- **Offline attack:** the attacker only needs to be near the AP for a few seconds to capture the WPA/WPA2 authentication handshake; once captured, cracking happens offline, away from the target, with no further risk of detection.
- **De-authentication attack (to force a handshake):** force a connected client to disconnect, then capture the reconnect and authentication packets (using aireplay-ng); the client usually re-authenticates within seconds, giving a fresh handshake to capture. Then dictionary brute-force the Pairwise Master Key (PMK).
- **Brute-force WPA keys:** use aircrack-ng and aireplay-ng together to attempt a dictionary-based brute force of the WPA key from the captured handshake.

Cracking WPA/WPA2 using Aircrack-ng (numbered steps from the demo):

Step 1 - Enable monitor mode: `airmon-ng start wlx00e02d886189`

Step 2 - List detected access points: `airodump-ng wlx00e02d886189`, reading BSSID, power, beacons, data rate, channel, encryption, cipher, authentication, and ESSID for every nearby AP.

Step 3 - Capture packets from the target AP only, writing to a file:

```
airodump-ng --bssid 22:7F:AC:6D:E6:8B -c 1 \
  -w ECCLabs wlx00e02d886189
```

Flag breakdown: `--bssid` filters capture to one AP; `-c 1` locks to channel 1; `-w ECCLabs` sets the output capture file prefix.

Step 4 - Send de-authentication packets to force a handshake:

```
aireplay-ng -0 11 -a 22:7F:AC:6D:E6:8B \
  -c EE:AB:46:A7:CF:18 wlx00e02d886189
```

Step 5 - Run aircrack-ng with a wordlist against the captured `.cap` file:

```
aircrack-ng -a2 22:7F:AC:6D:E6:8B \
  -w password.txt ECCLabs-01.cap
```

Flag breakdown: `-a2` forces WPA/WPA2 cracking mode; `-w password.txt` is the wordlist file; the last argument is the capture file containing the handshake.

Step 6 - Read the result: aircrack-ng tries each wordlist entry against the captured handshake and reports progress and, if successful, the recovered key.

Sample output read-through:

```
Aircrack-ng 1.7
[00:00:00] 8/16 keys tested (1201.02 k/s)
Time left: 0 seconds                      50.00%
KEY FOUND! [ 12345678 ]
```

How to read it: "8/16 keys tested" shows progress through the wordlist; "1201.02 k/s" is the cracking speed in keys per second; "KEY FOUND!" followed by the bracketed value is the recovered passphrase, here the weak password "12345678", which is exactly why wordlist attacks succeed so often against real-world networks.

Real-world use: A tester captures a handshake in under a minute by deauthenticating a known client, then cracks the PSK in seconds because the client used a common password found in any standard wordlist (such as rockyou.txt).

Tools and commands used here: airmon-ng, airodump-ng, aireplay-ng, aircrack-ng.

Countermeasures and defense: Use WPA3-SAE if supported (resistant to offline dictionary attacks); otherwise use a long, random passphrase (section 3.35) that will not appear in any wordlist.

EXAM FOCUS: Flag recall is common: `-a2` for WPA mode in aircrack-ng, `-w` for wordlist, `-c` for channel/client depending on tool context (airodump-ng's `-c` sets channel, aireplay-ng's `-c` sets client MAC in some modes). Output reading: know that "KEY FOUND!" with a bracketed value is the recovered PSK, not a hash.

Memory trick: "Capture the handshake, then crack it at home: the offline WPA attack."

3.31 WPA Brute Forcing Using Fern Wifi Cracker

What it is (simple words): Fern Wifi Cracker is a GUI tool that wraps the entire Aircrack-ng-style WPA/WPA2 attack workflow (monitor mode, scanning, de-authentication, handshake capture, wordlist cracking) into point-and-click steps, useful for beginners or quick demonstrations.

How it works (numbered steps from the notes):

1. Run `sudo fern-wifi-cracker` to start the tool.
2. Select the Wi-Fi adapter from the drop-down menu and click "Monitor Mode" to enable it.
3. Click "Scan for Access Points" to list nearby Wi-Fi networks, then select a target WPA/WPA2 network.
4. Click "Attack" next to the target network to start de-authenticating connected clients.
5. Wait for the tool to notify a successful WPA handshake capture.
6. Choose a wordlist file of candidate passwords to test against the captured handshake.
7. Click "Start WPA Attack"; if the password is found, it displays on screen.

Sample result fields shown: `WPA KEY: pterodactyl`, `WPS PIN: 39586513` (example values from the demo screenshot).

Analogy: Fern Wifi Cracker is the automatic transmission version of the Aircrack-ng manual-shift workflow: same engine underneath, fewer commands to remember.

Real-world use: A trainer demonstrates a live WPA2 crack to students in a classroom using Fern because its GUI is easier to follow step by step than typing raw Aircrack-ng commands.

Tools and commands used here: Fern Wifi Cracker (built on Aircrack-ng under the hood).

Countermeasures and defense: Same as section 3.30 and 3.35: strong passphrase, WPA3-SAE, WPS disabled.

EXAM FOCUS: "Which tool provides a graphical front end for WPA/WPA2 cracking, built on the same underlying attack steps as Aircrack-ng?" -> Fern Wifi Cracker. It is commonly placed as a look-alike option next to "aircrack-ng" in multiple-choice questions; pick based on whether the question says "GUI" (Fern) or "command line" (Aircrack-ng suite).

Memory trick: "Fern: Aircrack-ng with a point-and-click skin."

3.32 WPA3 Encryption Cracking (Dragonblood)

What it is (simple words): Dragonblood is the name given to a set of vulnerabilities discovered in WPA3's Dragonfly (SAE) handshake. It lets attackers recover keys, downgrade security to WPA2, and run information-theft attacks against WPA3 networks.

Dragonblood tool family: Dragonslayer, Dragonforce, Dragondrain, and Dragontime, each exploiting a different part of the flaw set.

Downgrade security attacks:

- **Exploiting backward compatibility:** the attacker installs a rogue AP and forces the victim into WPA2 encryption (transition-mode networks that support both WPA2 and WPA3 are exploitable this way), then runs all standard WPA2 attacks (section 3.30) against the downgraded connection.
- **Exploiting the Dragonfly handshake:** a rogue AP discards the user's WPA3 Dragonfly mechanism entirely, forcing the client onto a weaker algorithm such as WPA2, then exploits WPA2 as usual.

Side-channel attacks:

- **Timing-based:** the attacker measures how long the Dragonfly handshake takes for different password guesses; the number of iterations the password-encoding process takes leaks information, letting the attacker shortlist likely passwords for further, faster attacks.
- **Cache-based:** the attacker installs malicious JavaScript on the client's browser and observes CPU cache memory-access patterns during the handshake, which can leak enough information to recover password material.

Analogy: WPA3's SAE handshake is a locked vault that resists being picked from the outside. Dragonblood does not pick the lock directly; it either tricks the owner into using an older, weaker vault (downgrade) or watches subtle vibrations and timing of the vault's dial (side channel) to shortcut the combination.

Real-world use: A researcher demonstrates that a WPA3 router running in "transition mode" (supporting both WPA2 and WPA3 clients for compatibility) can still be downgraded and attacked exactly like a WPA2-only network, pushing the vendor to offer a pure WPA3-only setting.

Tools and commands used here: Dragonslayer, Dragonforce, Dragondrain, Dragontime.

Countermeasures and defense: Disable transition mode once all client devices support WPA3; keep router firmware updated with Dragonblood patches; avoid JavaScript-capable captive portals during authentication where side-channel timing could be measured.

EXAM FOCUS: "Which set of vulnerabilities affects WPA3's SAE/ Dragonfly handshake, enabling downgrade and side-channel attacks?" -> Dragonblood. Trap: Dragonblood does not mean

"WPA3 is as weak as WEP"; it specifically targets transition-mode downgrade paths and implementation-level side channels, not the core AES-GCMP-256 cipher.

Memory trick: "Dragonblood bleeds WPA3 back down to WPA2, or leaks timing clues from the Dragonfly dance."

3.33 Cracking WPA3 Using Aircrack-ng and Hashcat

What it is (simple words): A practical workflow to capture and crack a WPA3 (or WPA2, since the same 4-way-handshake-derived PMKID/ EAPOL data format is used) handshake using Aircrack-ng for capture and hashcat for high-speed GPU-accelerated cracking.

How it works (numbered steps from the notes):

Step 1 - Set the wireless interface to monitor mode: `airmon-ng start <Wireless_Interface>`

Step 2 - Capture the handshake as root: `airodump-ng wlan0mon`

Step 3 - De-authenticate a client to force a fresh handshake:

```
aireplay-ng --deauth 10 -a <BSSID> \
  -c <Client_MAC> wlan0mon
```

Step 4 - Convert the captured `.cap` file to `.hccapx` format for hashcat: `hcxpcapngtool -o capture.hccapx <capture>.cap`

Step 5 - Crack the handshake with hashcat and a wordlist:
`hashcat -m 22000 capture.hccapx /path/to/wordlist.txt`

Flag and tool breakdown:

Item	Meaning
airmon-ng start	Enable monitor mode on the interface
airodump-ng	Capture raw 802.11 frames including the handshake
aireplay-ng --deauth 10	Send 10 deauth packets to force reconnect
hcxpcapngtool -o	Convert .cap/.pcapng to hashcat's input format
hashcat -m 22000	Select hash mode 22000 (WPA-PBKDF2-PMKID+EAPOL)

> **ADDED CONTEXT:** hashcat mode 22000 is the modern combined mode for WPA-PBKDF2-PMKID+EAPOL captures (replacing the older separate modes 2500/16800 in current hashcat releases, verify against the hashcat version in use). GPU acceleration makes hashcat far faster than CPU- only aircrack-ng for large wordlists or brute-force character sets.

Real-world use: A tester with a GPU-equipped workstation captures a handshake in the field with Aircrack-ng tools, then moves the capture file to a cracking rig running hashcat for a much faster offline dictionary attack than aircrack-ng alone could manage.

Tools and commands used here: airmon-ng, airodump-ng, aireplay-ng, hcxpcapngtool, hashcat.

Countermeasures and defense: Same as sections 3.30, 3.32, 3.35: a long random passphrase, WPA3-SAE without transition mode, and keeping firmware patched against Dragonblood-class flaws.

EXAM FOCUS: "Which tool converts a capture file for use with hashcat?" -> hcxpcapngtool. "Which hashcat mode number targets WPA-PBKDF2-PMKID+EAPOL captures?" -> 22000 (memorize this number, it is a specific and testable detail).

Memory trick: "Capture with Air-tools, convert with hcx, crack with hashcat mode 22000."

3.34 Cracking WPS Using Reaver

What it is (simple words): Reaver automates brute-forcing the 8-digit WPS PIN of a vulnerable router. Because of a design flaw in many WPS implementations, the PIN can effectively be guessed in two smaller halves rather than as one full 8-digit number, making the attack much faster than a true 10^8 brute force.

How it works (numbered steps from the notes):

1. Set up the wireless interface in monitor mode using airmon-ng: `airmon-ng start wlx00e02d886189` (the notes show airmon-ng warning about competing processes like NetworkManager and wpa_supplicant that should be killed first with `airmon-ng check kill` to avoid interference).
2. Use the Wash utility (section 3.14) to detect WPS-enabled devices and check their lock status.
3. If Wash cannot detect devices, fall back to airodump-ng to find devices advertising WPS.
4. After identifying the target BSSID, start cracking the WPS PIN with Reaver.

Sample Reaver output read-through:

```
[+] Trying pin "12345670"
[+] Sending authentication request
[*] Sending association request
[+] Associated with 5C:64:8E:FD:8D:60 (ESSID: Airtel_Zerotouch)
[+] Sending EAPOL START request
[+] Received identity request
[+] Sending identity response
[+] Received M1 message
[+] Sending M2 message
[+] Received WSC NACK
[+] Sending WSC NACK
[E] WPS transaction failed (code: 0x04), re-trying last pin
```

How to read it: each "Trying pin" line is one WPS PIN guess; the M1/M2 messages are part of the WPS Enrollee/Registrar protocol exchange; a "WSC NACK" (Wi-Fi Simple Configuration Negative Acknowledgement) with "code: 0x04" means that PIN guess failed, so Reaver retries. Lines later in the capture show "Received deauth request" and a "WARNING: Receive timeout occurred", meaning the AP actively pushed back by de-authenticating Reaver's own connection attempts, a common anti-brute- force defense that slows, but given enough time and an unlocked AP, does not always fully stop the attack.

Real-world use: A tester finds an unlocked, WPS-enabled home router in range (via Wash) and runs Reaver overnight; because WPS PINs can be tested as two shorter halves, Reaver often succeeds within hours and reveals the full WPA2 passphrase through the router's WPS exchange, bypassing the need to crack the passphrase itself.

Tools and commands used here: airmon-ng, wash, airodump-ng, reaver.

Countermeasures and defense: Disable WPS entirely; if it must be on, ensure PIN lockout is enabled and working, and monitor for repeated authentication/association attempts from the same MAC.

EXAM FOCUS: "Which tool brute forces the WPS PIN to recover a router's WPA/WPA2 passphrase?" -> Reaver. Trap: Reaver depends on WPS being enabled and not permanently locked; a router with WPS disabled is immune to this specific attack path, even if its WPA2 passphrase is otherwise crackable by other means.

Memory trick: "Reaver reaps the PIN, two halves at a time."

3.35 Wireless Attack Countermeasures (WPA/WPA2/WPA3 and aLTEr)

What it is: A consolidated defense checklist for cracking-resistant passphrases, protocol hardening, and LTE/DNS-level protections.

Defense against WPA/WPA2/WPA3 cracking:

- Use a password of at least 12 to 16 characters, mixing uppercase, lowercase, numbers, and special characters.
- Disable TKIP in router settings; ensure only AES encryption is used.
- Turn off WPS to prevent brute-force attacks on the WPS PIN.
- Check the manufacturer's website regularly for firmware updates and apply them promptly.
- Limit the Wi-Fi signal range to reduce unauthorized access chances from outside the premises.
- Use network monitoring tools to detect and respond to suspicious activity.
- Use WPA3-SAE wherever all devices support it.
- Disable transition mode once all devices support WPA3, for the highest level of security.

Defense against the aLTEr attack (DNS-focused, repeated from section 3.27 for completeness as a countermeasure list):

- Encrypt DNS queries and use only trusted DNS resolvers.
- Resolve DNS queries using HTTPS (DoH).
- Use DNS over TLS or DTLS (DoT) for encryption and integrity of DNS traffic.
- Implement RFC 7858 / RFC 8310 to prevent DNS spoofing attacks.
- Use the DNSCrypt protocol to authenticate client-resolver communication.
- Use strong end-to-end encryption such as AES-256 for all communications.
- Use mutual authentication to verify both parties' identities.

Real-world use: A security team rolls out a policy requiring every new AP purchase to support WPA3-SAE, disables WPS fleet-wide, and enables DoH on all managed laptops to reduce exposure to both offline WPA cracking and aLTEr-style DNS redirection.

EXAM FOCUS: This list is a direct source of "which control stops X" questions. Map each bullet back to the specific attack it defeats: long passphrase -> dictionary/brute-force cracking; disable TKIP -> WPA/TKIP-specific attacks; disable WPS -> Reaver/PIN brute force; disable transition mode -> Dragonblood downgrade attacks; DoH/DoT/ DNSCrypt -> aLTEr-style DNS spoofing.

Memory trick: "Long password, AES only, WPS off, patch often, SAE pure (no transition mode), encrypt DNS."

3.36 Detection and Blocking of Rogue APs

What it is (simple words): Three practical techniques to find a rogue AP already on or near the network, plus two direct ways to disable one once found.

Detection of rogue APs:

- **RF scanning:** repurposed APs that only capture and analyze packets (RF sensors) are placed throughout the wired network to detect and warn the WLAN administrator about any wireless devices operating in the area.
- **AP scanning:** APs capable of detecting neighboring APs expose that data through their Management Information Base (MIB) and web interface, letting an administrator spot unexpected neighbors.
- **Wired side inputs:** network management software detects devices connected to the LAN using multiple protocols, including Telnet, SNMP, and Cisco Discovery Protocol (CDP), to catch rogue devices plugged directly into switch ports.

Blocking of rogue APs:

- Deny wireless service to new clients by launching a denial-of-service attack on the rogue AP itself (an authorized, controlled countermeasure, not the attacker's DoS from section 3.19).
- Block the switch port the rogue AP is connected to, or manually locate the AP and physically remove it from the LAN.

Analogy: RF scanning is like having guards who sniff for intruders in the air; AP scanning is neighboring buildings reporting strangers they see; wired-side inputs are front-desk logs showing who badged into the building through a cable. Blocking is either jamming the intruder's radio or physically walking over and unplugging them.

Real-world use: A company's WIPS flags an unknown BSSID using the corporate SSID near the finance department (RF scanning); IT cross- references switch CDP data (wired side input) to trace it to a specific switch port, then disables that port, cutting the rogue AP off the network.

Tools and commands used here: Dedicated WIPS products (section 3.38), SNMP/CDP-aware network management software.

EXAM FOCUS: "Which detection method uses CDP, SNMP, and Telnet to find rogue devices connected to the wired LAN?" -> wired side inputs. Trap: RF scanning finds rogue APs by radio signal; wired side inputs find them by tracing LAN connections; they are complementary, not interchangeable.

Memory trick: "RF listens, AP neighbors tattle, wires trace the cable back to the plug."

3.37 Defense Against Wireless Attacks (Best Practices)

What it is: A broad best-practices checklist grouped into configuration, SSID settings, and authentication, covering the module's overall defensive posture.

Best practices for configuration:

- Change the default SSID after WLAN configuration.
- Set the router access password and enable firewall protection.
- Disable SSID broadcasts.
- Disable remote router login and wireless administration.
- Enable MAC address filtering on the AP or router.
- Enable encryption on the AP and change the passphrase often.

Best practices for SSID settings:

- Use SSID cloaking to keep certain default wireless messages from broadcasting the ID to everyone (a minor obscurity layer only; see section 3.18's trap).
- Do not use the SSID, company name, network name, or any easy-to-guess string inside passphrases.
- Place a firewall or packet filter between the AP and the corporate intranet.
- Limit the wireless network's signal strength to avoid detection outside the bounds of the organization.
- Regularly check wireless devices for configuration or setup problems.
- Implement an additional encryption technique for traffic, such as IPsec over wireless.

Best practices for authentication:

- Enable WPA3 for the highest level of security.
- If WPA3 is not supported by all devices, use WPA2 with AES encryption.
- Use 802.1X authentication with a RADIUS server for enterprise networks.
- Disable the network when it is not required.
- Place wireless APs in a secure physical location.
- Keep drivers on all wireless equipment updated.
- Use a centralized server for authentication.

Real-world use: A new-office rollout checklist requires: unique SSID (not the company name), WPA3 (or WPA2-AES minimum), RADIUS/802.1X for staff devices, MAC filtering as a secondary control, AP transmit power tuned to stay inside the building footprint, and quarterly firmware/driver update reviews.

EXAM FOCUS: This checklist is often tested as "which of the following is NOT a good practice" or "which control is weakest on its own." Remember that SSID cloaking and MAC filtering are both weak individually (sections 3.18, 3.21) but acceptable as extra layers on top of strong encryption and authentication, never as the primary control.

Memory trick: "Configure, Conceal (lightly), Authenticate (strongly): three best-practice groups, in that order."

3.38 Wi-Fi Security Auditing Tools

What it is (simple words): Dedicated Wireless Intrusion Prevention System (WIPS) products and auditing tools that detect and mitigate wireless threats for defenders, as opposed to the attacker-side tools covered earlier in the module.

- **WIPS (Wireless Intrusion Prevention System):** a system that monitors the radio spectrum for threats (rogue APs, Evil Twins, jamming, deauth floods) and can automatically respond, for example by containing a rogue AP.

Tools named in the notes:

Tool	What it does	Link
Cisco Adaptive Wireless IPS	Detects/mitigates wireless threats	cisco.com
WatchGuard Wi-Fi Cloud WIPS	Defends airspace, near-zero false positives	watchguard.com
RFProtect	Wireless threat detection and protection suite	arubanetworks.com
Fern Wifi Cracker	Also used to audit your own network (see 3.31)	github.com
OSWA-Assistant	Open-source wireless auditing toolkit	securitystartshere.org

Tool	What it does	Link
BoopSuite	Open-source Wi-Fi auditing tool suite	github.com
Wifite	Automated Wi-Fi auditing/attack tool	github.com

How it works (Cisco Adaptive WIPS, general concept): Cisco's WIPS provides wireless-network threat detection and mitigation against malicious attacks, giving administrators the ability to detect, analyze, and identify wireless threats across managed APs, with alert views showing detected incidents by severity, category, and time period.

Real-world use: An enterprise deploys Cisco Adaptive Wireless IPS across its campus APs. When an Evil Twin using the corporate SSID appears in the parking lot, the WIPS alerts security staff with the rogue BSSID, its location estimate, and severity, enabling a fast physical or RF-based response.

Countermeasures and defense: Running a WIPS is itself the countermeasure; it operationalizes the detection methods from section 3.36 (RF scanning, AP scanning, wired side inputs) as a continuous, automated service rather than a one-time audit.

EXAM FOCUS: "Which category of tool continuously monitors for rogue APs, Evil Twins, and wireless DoS attacks, and can respond automatically?" -> a WIPS (such as Cisco Adaptive Wireless IPS or WatchGuard Wi-Fi Cloud WIPS). Distinguish these commercial, continuous WIPS products from one-off attacker/auditor tools like Wifite or Fern Wifi Cracker, which are typically run on demand by a person, not deployed as a standing defensive service.

Memory trick: "WIPS watches the air all day; Wifite and Fern are one-time toolkits a person runs by hand."

4. Tool Encyclopedia

Tool	What it does (simple)	Type/platform	Phase used	Exam keyword
airmon-ng	Enables/disables monitor mode	Linux, Aircrack-ng suite	Discovery	"enable monitor mode"
airodump-ng	Captures raw 802.11 frames, WEP IVs	Linux, Aircrack-ng suite	Discovery/Traffic analysis	"capture handshake/IVs"
aireplay-ng	Injects frames, deauth, fake auth	Linux, Aircrack-ng suite	Attacks	"--deauth", "inject"
aircrack-ng	Cracks WEP and WPA/WPA2-PSK	Linux/Windows, Aircrack-ng suite	Encryption cracking	"crack the PSK"
airdecap-ng	Decrypts WEP/WPA/WPA2 captures	Linux, Aircrack-ng suite	Post-cracking	"strip wireless headers"

Tool	What it does (simple)	Type/platform	Phase used	Exam keyword
airdrop-ng	Targeted, rule-based deauth	Linux, Aircrack-ng suite	Attacks	"rule-based de-auth"
airolib-ng	Stores ESSID/ password lists	Linux, Aircrack-ng suite	Encryption cracking	"store password list"
airbase-ng	Fake AP, captures handshakes	Linux, Aircrack-ng suite	Attacks	"ad-hoc AP"
mdk3 / mdk4	Brute forces hidden SSIDs, DoS	Linux	Discovery/Attacks	"hidden SSID bruteforce"
Wash	Finds WPS-enabled APs, lock state	Linux, Reaver project	Discovery	"WPS enabled, locked"
Reaver	Brute forces WPS PIN	Linux	Encryption cracking	"WPS PIN brute force"
inSSIDer	Maps active wireless networks	Windows/macOS	Discovery	"drive/walk to map Wi-Fi"
Sparrow-Wifi Analyzer	GUI Wi-Fi scanner and analyzer	Linux	Discovery	"security, channel, signal list"
Acrylic Wi-Fi Heatmaps	Wi-Fi heatmap and scanner	Windows	Discovery	"signal heatmap"
WirelessMon	Wi-Fi monitoring, site survey	Windows	Discovery	"site survey"
Ekahau Wi-Fi Heatmaps	Professional Wi-Fi heatmaps	Windows/macOS	Discovery	"professional heatmap"
Wireshark	Captures/analyzes 802.11 traffic	Cross-platform	Traffic analysis	"open-source packet analyzer"
AirMagnet WiFi Analyzer Pro	Enterprise Wi-Fi traffic analysis	Windows	Traffic analysis	"enterprise Wi-Fi analysis"
OmniPeek	Commercial packet analyzer	Windows	Traffic analysis	"commercial packet analyzer"
CommView for Wi-Fi	Windows Wi-Fi sniffer	Windows	Traffic analysis	"Wi-Fi sniffer"
Technitium MAC Address Changer	Spoofs the NIC MAC address	Windows	Attacks	"instant MAC spoofing GUI"
LizardSystems Change MAC Address	Spoofs the NIC MAC address	Windows	Attacks	"MAC address changer"
arpspoof	Poisons ARP tables	Linux	Attacks	"ARP poisoning tool"
Ettercap	ARP poisoning, sniffing, MITM	Cross-platform	Attacks	"unified sniffing, MITM menu"

Tool	What it does (simple)	Type/platform	Phase used	Exam keyword
MANA Toolkit	Rogue AP / Karma attack framework	Linux	Attacks	"hostapd-mana, Karma"
hostapd-wpe	Rogue AP for credential capture	Linux	Attacks	"Wi-Jacking, Karma"
dnsmasq	DNS/DHCP server, used to inject URLs	Linux	Attacks	"inject malicious URL"
tcpdump	Captures packets from the CLI	Linux	Traffic analysis	"capture rogue AP traffic"
Dragonslayer	Exploits WPA3 Dragonfly flaws	Linux	Encryption cracking	"Dragonblood tool"
Dragonforce	Exploits WPA3 Dragonfly flaws	Linux	Encryption cracking	"Dragonblood tool"
Dragondrain	Exploits WPA3 Dragonfly flaws	Linux	Encryption cracking	"Dragonblood tool"
Dragontime	Timing side-channel on Dragonfly	Linux	Encryption cracking	"timing side channel"
hcxpcapngtool	Converts captures for hashcat	Linux	Encryption cracking	"convert to hccapx"
hashcat	GPU-accelerated hash/key cracking	Cross-platform	Encryption cracking	"mode 22000"
Fern Wifi Cracker	GUI WEP/WPA/ WPA2 cracking suite	Linux	Encryption cracking	"GUI WPA attack"
iCopy-X	Portable RFID cloning device	Hardware	Attacks	"stand-alone RFID cloner"
RFIDler	Open-source RFID tool	Hardware	Attacks	"RFID read/write tool"
Flipper Zero	Multi-tool incl. RFID clone	Hardware	Attacks	"pocket multi-tool"
Cisco Adaptive Wireless IPS	Wireless threat detection/ mitigation	Enterprise WIPS	Defense	"detect and mitigate wireless threats"
WatchGuard Wi-Fi Cloud WIPS	Defends airspace, low false positives	Enterprise WIPS	Defense	"near-zero false positives"
RFProtect	Wireless threat detection suite	Enterprise WIPS	Defense	"wireless threat detection"
OSWA-Assistant	Open-source wireless auditing kit	Linux	Defense/audit	"open-source Wi-Fi audit"
BoopSuite	Open-source Wi-Fi auditing suite	Linux	Defense/audit	"open-source audit suite"

Tool	What it does (simple)	Type/platform	Phase used	Exam keyword
Wifite	Automated Wi-Fi auditing tool	Linux	Discovery/Attacks/ Cracking	"automated Wi-Fi attack"
KisMAC	Wi-Fi scanner, chipset-dependent	macOS	Discovery	"chipset-specific scanner"

> **ADDED CONTEXT:** The exam sometimes names close alternatives not in these screenshots. Kismet is the cross-platform, actively maintained cousin of KisMAC and is often listed next to Wireshark/ airodump-ng as a passive wireless detector. Bettercap is a modern alternative to Ettercap for MITM and network attacks, worth recognizing by name.

5. Command Sheet

5.1 airmon-ng

Purpose: Switch a wireless interface between managed mode (normal use) and monitor mode (needed to capture and inject raw 802.11 frames).

Full syntax: `airmon-ng <start|stop|check> <interface>`

Breakdown:

Part	Meaning
start	Enable monitor mode on the given interface
stop	Disable monitor mode, return to managed mode
check kill	Kill processes (NetworkManager, wpa_supplicant) that interfere
interface	The wireless NIC name, for example wlan0

Flag table:

Flag/subcommand	Meaning	When to use	Example
start	Turn on monitor mode	Before any capture/ injection	airmon-ng start wlan0
stop	Turn off monitor mode	When finished testing	airmon-ng stop wlan0mon
check	List interfering processes	Before start, if start fails	airmon-ng check
check kill	Kill interfering processes	If start reports conflicts	airmon-ng check kill

Demo commands:

```
airmon-ng check kill
airmon-ng start wlx00e02d886189
airmon-ng stop wlan0mon
```

Sample output:

```
PHY  Interface        Driver   Chipset
phy2 wlx00e02d886189   mt7601u  Ralink Tech. MT7601U
                       (monitor mode enabled)
```

How to read it: the chipset line confirms the driver and chipset, and the tag "(monitor mode enabled)" confirms the command worked; the interface name often changes (for example to wlan0mon) once monitor mode is active.

Common mistakes: forgetting to kill NetworkManager/wpa_supplicant first, which can silently flip the card back to managed mode or hop channels; using the old interface name after airmon-ng renames it.

What the exam asks: which subcommand enables monitor mode (start), and why `check kill` matters before starting capture.

5.2 airodump-ng

Purpose: Passively capture raw 802.11 frames from nearby networks, including beacons, data frames, and handshakes, and optionally save them to a file.

Full syntax: `airodump-ng [--bssid <BSSID>] [-c <channel>] [-w <file>] <interface>`

Flag table:

Flag	Meaning	When to use	Example
--bssid	Filter capture to one AP	Target one specific network	--bssid AA:BB:CC:DD:EE:FF
-c	Lock capture to one channel	Target is on a known channel	-c 6
-w	Write capture to file prefix	Need to save for cracking	-w capture
--ivs	Save only IVs (WEP cracking)	Cracking WEP specifically	--ivs -w capture

Demo commands:

```
airodump-ng wlx00e02d886189
airodump-ng --bssid 22:7F:AC:6D:E6:8B -c 1 \
  -w ECCLabs wlx00e02d886189
```

Sample output:

```
BSSID              PWR  Beacons  CH  ENC  CIPHER  AUTH  ESSID
22:7F:AC:6D:E6:8B  -45  65       11  WPA2 CCMP    PSK   ECC Labs
```

How to read it: PWR closer to 0 means a stronger (closer) signal; ENC/ CIPHER/AUTH show the encryption generation, cipher suite, and authentication type, which tells the attacker exactly which cracking approach applies (WEP cracking vs WPA/WPA2 handshake capture).

Common mistakes: not locking the channel with `-c` while also trying to capture a handshake, which can cause missed frames as the card hops channels; forgetting `-w` and losing the capture when the terminal closes.

What the exam asks: reading the AP list columns (especially ENC/ CIPHER/AUTH) and knowing `-w` saves a capture file for later cracking.

5.3 aireplay-ng

Purpose: Inject 802.11 frames, most commonly to de-authenticate a client (forcing a handshake) or to fake-authenticate the attacker's own card to an AP.

Full syntax: `aireplay-ng --deauth <count> -a <AP_BSSID> [-c <client_MAC>] <iface>`

Flag table:

Flag	Meaning	When to use	Example
--deauth N	Send N deauth packets	Force a client to reconnect	--deauth 10
-0 N	Same as --deauth N (short form)	Quick deauth burst	-0 11
-a	Target AP's BSSID	Always required for deauth	-a 22:7F:AC:6D:E6:8B
-c / -h	Target client MAC / spoofed source	Target one specific client	-c EE:AB:46:A7:CF:18
-1 0	Fake authentication, 0 delay	Associate without real creds	-1 0 -e SSID -a BSSID

Demo commands:

```
aireplay-ng --deauth 25 -h <TARGET_MAC> \
  -b <AP_MAC> ath1
aireplay-ng -1 0 -e SECRET_SSID -a 1e:64:51:3b:ff:3e \
  -h 02:24:2B:CD:68:EE eth1
```

Sample output:

```
Sending 64 directed DeAuth (code 7).
STMAC: [EE:AB:46:A7:CF:18] [27|69 ACKs]
```

How to read it: "[27|69 ACKs]" means 27 of the frames sent so far were acknowledged out of 69 total attempts; a nonzero ACK count is evidence the target device is receiving the injected frames.

Common mistakes: confusing `-b` (older flag for AP BSSID in some versions) with `-a`; using `-c`/`-h` inconsistently between deauth mode (target client) and fake-auth mode (attacker's spoofed MAC).

What the exam asks: what `--deauth`/`-0` does, why a short deauth burst is used before capturing a handshake, and reading the ACK count in the output.

5.4 aircrack-ng

Purpose: Crack a WEP key from captured IVs, or a WPA/WPA2-PSK key from a captured 4-way handshake, using a wordlist or brute force.

Full syntax: `aircrack-ng -a <1|2> [-w <wordlist>] <capture_file>`

Flag table:

Flag	Meaning	When to use	Example
-a 1	Force WEP cracking mode	Target uses WEP	-a 1 capture.ivs
-a 2	Force WPA/WPA2 cracking mode	Target uses WPA/WPA2	-a2 capture-01.cap
-w	Wordlist file for dictionary attack	Cracking a WPA/WPA2 PSK	-w password.txt
-b	Restrict to one BSSID in the capture	Capture has multiple APs	-b 22:7F:AC:6D:E6:8B

Demo commands:

```
aircrack-ng -a2 22:7F:AC:6D:E6:8B \
  -w password.txt ECCLabs-01.cap
```

Sample output:

```
[00:00:00] 8/16 keys tested (1201.02 k/s)
KEY FOUND! [ 12345678 ]
```

How to read it: the fraction shows progress through the wordlist, the rate (k/s) shows cracking speed, and "KEY FOUND!" with a bracketed value is the recovered PSK in plaintext.

Common mistakes: running aircrack-ng without a completed 4-way handshake in the capture file (it will fail to crack, since it has nothing to test against); using a tiny or irrelevant wordlist for a real-world strong password.

What the exam asks: which flag selects WPA mode (-a2) versus WEP mode (-a1), and how to read "KEY FOUND!" output.

5.5 mdk3 (hidden SSID brute force)

Purpose: Probe for and brute-force a hidden (non-broadcast) SSID by sending probe requests for every possible SSID string until the target AP responds.

Full syntax: `mdk3 <interface> p -b <mode> -c <channel> -t <BSSID>`

Flag table:

Flag	Meaning	When to use	Example
p	SSID probe/bruteforce mode	Hidden SSID discovery	mdk3 wlan0mon p
-b	Character set/bruteforce option	Control guess character set	-b 1
-c	Channel to use	Match the target AP's channel	-c 2
-t	Target BSSID	Focus on one specific AP	-t 1C:3B:F3:40:10:74

Demo command:

```
mdk3 wlx00e02d886189 p -b 1 -c 2 \
  -t 1C:3B:F3:40:10:74
```

Sample output:

```
All 676 possible SSIDs with length 2 sent, trying length 3.
Got response from 1C:3B:F3:40:10:74, SSID: "ECC Labs"
```

How to read it: mdk3 reports progress by SSID length (trying all 1- character guesses, then 2-character, and so on); "Got response" followed by the SSID is the recovered hidden network name.

Common mistakes: not setting `-c` to match the AP's real channel, which prevents any response from reaching the tool; expecting instant results against long or complex SSIDs, since brute force time grows quickly with SSID length.

What the exam asks: that hidden SSID is not real security, and that `-t` targets a BSSID in this command.

5.6 Wash and Reaver (WPS attack chain)

Purpose: Wash finds WPS-enabled APs and their lock state; Reaver brute forces the WPS PIN of an unlocked target to recover the WPA/WPA2 passphrase.

Full syntax: `wash -i <interface>` then `reaver -i <interface> -b <BSSID> -c <channel>`

Flag table:

Flag	Meaning	When to use	Example
-i	Interface to use	Always required	-i wlan0mon
-b	Target AP BSSID (Reaver)	Always required for Reaver	-b 5C:64:8E:FD:8D:60
-c	Target channel (Reaver)	Speeds up the attack	-c 6

Demo commands:

```
sudo wash -i wlan0
reaver -i wlan0mon -b 5C:64:8E:FD:8D:60 -c 6
```

Sample output (Reaver):

```
[+] Trying pin "12345670"
[+] Associated with 5C:64:8E:FD:8D:60
   (ESSID: Airtel_Zerotouch)
[+] Received WSC NACK
[E] WPS transaction failed (code: 0x04),
   re-trying last pin
```

How to read it: "Trying pin" shows the current guess; "WSC NACK" with a failure code means that guess was rejected and Reaver will retry with the next PIN candidate; a successful run eventually prints the recovered WPA/WPA2 passphrase.

Common mistakes: targeting a locked WPS AP (locked APs will refuse or stall every attempt); not matching the correct channel, slowing the attack.

What the exam asks: that Wash discovers, Reaver cracks; that WPS lockout is the main defense that slows this attack.

5.7 MAC spoofing (ifconfig / ip link)

Purpose: Change a network interface's MAC address to bypass MAC filtering or to impersonate another device.

Full syntax (classic): `ifconfig <iface> down`, `ifconfig <iface> hw ether <MAC>`, `ifconfig <iface> up`

Full syntax (modern): `ip link set dev <iface> down`, `ip link set dev <iface> address <MAC>`, `ip link set dev <iface> up`

Flag table:

Command part	Meaning	When to use	Example
down	Disable the interface	Required before MAC change	ifconfig wlan0 down
hw ether	Set new MAC (ifconfig style)	Classic method	hw ether 02:25:ab:4c:2a:bc
address	Set new MAC (ip link style)	Modern method	address 00:11:22:33:44:55
up	Re-enable the interface	After setting the new MAC	ifconfig wlan0 up

Demo commands:

```
ifconfig wlan0 down
ifconfig wlan0 hw ether 02:25:ab:4c:2a:bc
ifconfig wlan0 up
```

Sample output: `ip link show eth0` after the change shows the new `link/ether 00:11:22:33:44:55` value in place of the original hardware MAC, confirming the spoof took effect.

Common mistakes: trying to change the MAC while the interface is still up (most drivers reject this); forgetting the change is not persistent across reboots unless explicitly saved.

What the exam asks: that the interface must be brought down first, and why MAC filtering is weak against this technique.

5.8 hashcat (WPA/WPA3 handshake cracking)

Purpose: GPU-accelerated cracking of a converted WPA/WPA2/WPA3 handshake capture using a wordlist or mask attack.

Full syntax: `hashcat -m 22000 <capture.hccapx> <wordlist.txt>`

Flag table:

Flag	Meaning	When to use	Example
-m 22000	Hash mode: WPA-PBKDF2-PMKID+EAPOL	Cracking WPA/WPA2/WPA3 captures	-m 22000
(positional 1)	Converted capture file	Always required	capture.hccapx
(positional 2)	Wordlist file	Dictionary attack	wordlist.txt

Demo command:

```
hcxpcapngtool -o capture.hccapx capture.cap
hashcat -m 22000 capture.hccapx \
  /path/to/wordlist.txt
```

Sample output: hashcat prints a status block with "Status: Cracked" once successful, followed by the capture's hash line with the recovered passphrase appended after a colon.

Common mistakes: forgetting to convert the `.cap` file with hcxpcapngtool first, feeding hashcat a raw pcap it cannot parse; using the outdated hash mode numbers (2500/16800) instead of 22000 for a recent hashcat version.

What the exam asks: hash mode number recall (22000) and the role of hcxpcapngtool as the conversion step before hashcat.

6. Ports, Protocols, Standards and Acronyms

Item	Simple purpose	Port/layer	Known weakness
802.11	Base Wi-Fi radio standard	Layer 1/2	Open to sniffing without encryption
802.11i	Defines WPA2 security	Layer 2	N/A, this is the security fix layer
802.1X	Port-based network access control	Layer 2	Depends on backend RADIUS security
EAP	Carries auth methods over 802.1X	Layer 2	Some EAP types (LEAP) are weak
RADIUS	Centralized AAA (auth, authz, acct)	UDP 1812/1813	Weak if shared secret is poor
WEP	Legacy Wi-Fi encryption	Layer 2	RC4 + tiny 24-bit IV, fully broken
WPA/TKIP	Patch encryption over WEP hardware	Layer 2	RC4-based, PSK brute-forceable
WPA2/CCMP	AES-based Wi-Fi encryption	Layer 2	KRACK nonce reuse, Hole196
WPA3/SAE	Password-based key exchange	Layer 2	Dragonblood downgrade/side-channel
WPS	Easy-setup PIN/button Wi-Fi join	Layer 2	PIN brute force via Reaver
ARP	Maps IP to MAC on a LAN	Layer 2/3	No authentication, spoofable
DNS	Resolves names to IP addresses	UDP/TCP 53	Spoofing without DoH/DoT/DNSSEC
DoH	DNS over HTTPS	TCP 443	N/A, this is itself a defense
DoT	DNS over TLS	TCP 853	N/A, this is itself a defense

Item	Simple purpose	Port/layer	Known weakness
LTE (4G)	Mobile broadband standard	Cellular layer	aLTEr DNS spoofing via fake tower
RFID	Short-range tag identification radio	Near field, varies	Static-ID tags are clonable
Bluetooth (802.15.1)	Short-range device pairing	2.4 GHz	Pairing/PIN attacks (outside module)
ZigBee (802.15.4)	Low-power IoT mesh radio	Sub-GHz/2.4 GHz	Weak key exchange in some devices
WiMAX (802.16)	Metro-area wireless broadband	2-11 GHz	Legacy, limited deployment today

> **ADDED CONTEXT:** RADIUS listens on UDP port 1812 for authentication and 1813 for accounting in the modern standard (older deployments used 1645/1646, verify which your target environment uses). CDP and SNMP, used for wired-side rogue AP detection (section 3.36), are Cisco Discovery Protocol (Layer 2, no IP needed) and Simple Network Management Protocol (UDP 161/162) respectively.

7. Attack vs Countermeasure and Look-alike Comparisons

Attack vs Countermeasure:

Attack	Countermeasure
WEP key cracking	Remove/replace all WEP devices
WPA/WPA2 PSK dictionary cracking	Long random passphrase, WPA3-SAE
KRACK (nonce reuse in 4-way handshake)	Vendor patches, prefer WPA3
Dragonblood downgrade/side-channel	Disable transition mode, patch firmware
WPS PIN brute force (Reaver)	Disable WPS entirely
Disassociation/De-authentication flood	802.11w Management Frame Protection
MAC spoofing to bypass filtering	Pair MAC filtering with 802.1X/RADIUS
Wireless ARP poisoning	Dynamic ARP inspection, static ARP, HTTPS/VPN
Rogue AP / Evil Twin	RF/AP/wired-side detection, WIPS, user training
MITM via deauth + fake AP	Mutual auth (certs), 802.11w, VPN
Jamming signal DoS	Spectrum analyzers, wired backup links
aLTEr DNS spoofing	DoH/DoT, DNSCrypt, RFC 7858/8310
Wi-Jacking (router credential theft)	Disable auto-restart triggers, HTTPS admin UI
RFID cloning	Challenge-response RFID, blocking sleeves

Look-alike comparisons:

X vs Y	Difference in one line	How to tell them apart
Disassociation vs De-authentication	Disassoc keeps auth; deauth removes both	Deauth forces full reconnect, disassoc may not
Rogue AP vs Evil Twin	Rogue AP is any unauthorized AP; Evil Twin copies a trusted SSID	Ask if the SSID impersonates a known network
MAC filtering vs 802.1X	MAC filtering checks a device; 802.1X checks a user	802.1X needs RADIUS, MAC filtering does not
WPA/TKIP vs WPA2/CCMP	TKIP patches RC4; CCMP replaces it with AES	Cipher name in capture: TKIP vs CCMP
KRACK vs Hole196	KRACK is handshake nonce reuse; Hole196 is insider GTK/MITM abuse	KRACK needs a cloned AP; Hole196 needs an insider
Wash vs Reaver	Wash finds WPS APs; Reaver cracks the PIN	"Discover" = Wash, "crack" = Reaver
Jamming vs Deauth flood	Jamming floods the spectrum; deauth abuses one frame type	Jamming hits all devices; deauth hits one client
Evil Twin vs aLTEr	Evil Twin clones a Wi-Fi SSID; aLTEr clones an LTE tower	Ask if the network is Wi-Fi or cellular

8. Exam Cheat Sheet

Keyword -> answer pairs:

- "24-bit IV, RC4, CRC-32" -> WEP
- "TKIP, Michael algorithm, 48-bit IV" -> WPA
- "AES-CCMP, CBC-MAC, mandatory security" -> WPA2
- "AES-GCMP-256, SAE, Dragonfly" -> WPA3
- "resistant to offline dictionary attacks" -> WPA3-SAE
- "stores ESSID and password lists" -> airolib-ng
- "enables monitor mode" -> airmon-ng
- "captures raw 802.11 frames" -> airodump-ng
- "injects deauth frames" -> aireplay-ng
- "cracks the WEP/WPA key" -> aircrack-ng
- "finds WPS-enabled APs" -> Wash
- "brute forces the WPS PIN" -> Reaver
- "clones a trusted SSID" -> Evil Twin
- "replays handshake Message 3" -> KRACK
- "downgrade/side-channel flaw set in WPA3" -> Dragonblood
- "fake LTE tower, DNS spoofing" -> aLTEr

- "steals a router's own admin credentials via Karma + cached page" -> Wi-Jacking
- "duplicates a physical access badge" -> RFID cloning
- "converts a capture for hashcat" -> hcxpcapngtool
- "hashcat mode for WPA-PBKDF2-PMKID+EAPOL" -> 22000

Must-memorize lists:

- 5-step wireless hacking methodology: Discovery, Traffic Analysis, Attacks, Encryption Cracking, Compromise.
- 5 wireless threat families: Access control, Integrity, Confidentiality, Availability, Authentication.
- 8 Aircrack-ng suite tools: airmon-ng, airodump-ng, aireplay-ng, aircrack-ng, airdecap-ng, airdrop-ng, airolib-ng, airbase-ng.
- 4 encryption generations in order: WEP -> WPA -> WPA2 -> WPA3.
- 4 Dragonblood tools: Dragonslayer, Dragonforce, Dragondrain, Dragontime.

Numbers and defaults to memorize:

- WEP IV size: 24 bits. WPA/WPA2 IV size: 48 bits. WPA3 nonce space: up to 2^64.
- WEP key length: 40/104-bit. WPA/WPA2 key length: 128-bit. WPA3 key length: 192-bit.
- WPA2-Personal passphrase length: 8 to 63 ASCII characters.
- Recommended passphrase length (countermeasure): 12 to 16+ characters.
- WPS PIN length: 8 digits, but crackable in two shorter halves.
- hashcat mode for modern WPA/WPA2/WPA3 handshake cracking: 22000.
- WPS lockout typically triggers after about 5 failed PIN attempts.

"Pick the BEST option" rules for this module:

- If a question gives both a weak layer-2 control (MAC filtering, SSID hiding) and a strong one (WPA3, 802.1X/RADIUS) as separate answer choices for "best defense", choose the strong one; the weak controls are only acceptable as additional layers, never as the primary answer.
- If a scenario mixes an availability symptom (clients dropping) with an authentication symptom (credentials stolen), classify by the attacker's actual goal, not just the visible symptom: KRACK looks like "just a dropped connection" to the victim, but the goal and correct classification is decrypting/injecting traffic (authentication/confidentiality), not pure availability.
- When asked "which tool" for a workflow step, match the exact verb in the question (enable/capture/inject/crack/convert) to the single Aircrack-ng/hashcat-chain tool that performs that verb; do not pick a tool that performs an adjacent step.

9. Practice Questions

Q1. A penetration tester captures 802.11 traffic and sees frames using a 24-bit initialization vector and a CRC-32 integrity check with no key management scheme. Which encryption protocol is in use? A. WPA B. WPA2 C. WEP D. WPA3

Answer: C. WEP is defined by its 24-bit IV, RC4 stream cipher, and CRC-32 checksum with no centralized key management, exactly as described. **A is wrong:** WPA uses a 48-bit IV and the Michael algorithm, not CRC-32 alone. **B is wrong:** WPA2 uses CBC-MAC inside AES-CCMP, not CRC-32. **D is wrong:** WPA3 uses BIP-GMAC-256 for integrity, not CRC-32.

Q2. Which Aircrack-ng suite tool is used specifically to store and manage ESSID and password lists for WPA/WPA2 cracking? A. airodump-ng B. airolib-ng C. airdecap-ng D. airbase-ng

Answer: B. airolib-ng's stated job in the notes is storing and managing ESSID and password lists used in WPA/WPA2 cracking. **A is wrong:** airodump-ng captures raw frames, it does not manage password databases. **C is wrong:** airdecap-ng decrypts captured traffic after the key is known. **D is wrong:** airbase-ng creates a fake AP.

Q3. An attacker sends a forged frame that leaves a client authenticated but no longer associated with its access point, allowing a fast reconnection. Which attack is this? A. De-authentication attack B. Disassociation attack C. Jamming attack D. KRACK

Answer: B. The notes define disassociation as leaving the client authenticated but not associated, enabling a quick reconnect. **A is wrong:** de-authentication removes both authentication and association. **C is wrong:** jamming floods the spectrum, it is not a single forged management frame. **D is wrong:** KRACK abuses handshake nonce reuse, unrelated to association state frames.

Q4. Which flag forces aircrack-ng into WPA/WPA2 cracking mode when processing a captured handshake file? A. -a 1 B. -a 2 C. -w D. -b

Answer: B. `-a 2` (also written -a2) forces WPA/WPA2 cracking mode in aircrack-ng. **A is wrong:** `-a 1` forces WEP cracking mode instead. **C is wrong:** `-w` supplies the wordlist file, not the crack mode. **D is wrong:** `-b` restricts the capture to one BSSID, it does not select the cracking mode.

Q5. A rogue access point is configured with the exact same SSID as a coffee shop's legitimate Wi-Fi network to trick customers into connecting. What is this specific attack called? A. Rogue AP B. Evil Twin C. Honeypot AP D. MITM

Answer: B. Copying a trusted, known SSID to lure victims is the defining trait of an Evil Twin. **A is wrong:** "Rogue AP" is the broader category; Evil Twin is the specific SSID-cloning variant. **C is wrong:** a honeypot AP is designed to attract and study attackers, not primarily to steal victim credentials by impersonation. **D is wrong:** MITM describes the position/role (between client and AP), not the SSID-cloning lure itself, although an Evil Twin is often used to set up a MITM.

Q6. Which WPA3 feature makes offline dictionary attacks against the password ineffective, unlike WPA2's 4-way handshake? A. AES-GCMP-256 B. SAE (Dragonfly Key Exchange) C. HMAC-SHA-384 D. ECDSA-384

Answer: B. SAE/Dragonfly requires a live exchange with the AP for every password guess, so an attacker cannot capture one exchange and brute force it offline at leisure. **A is wrong:** GCMP-256 is the cipher for confidentiality/integrity, not the key-exchange method. **C is wrong:** HMAC-SHA-384 is used for key derivation in WPA3-Enterprise, not the resistance to offline guessing. **D is wrong:** ECDSA-384 is used for key exchange in WPA3-Enterprise, not the Personal-mode dictionary resistance.

Q7. An administrator finds an unauthorized access point plugged directly into an office Ethernet jack using Cisco Discovery Protocol (CDP) data from the network management system. Which rogue AP detection method was used? A. RF scanning B. AP scanning C. Wired side inputs D. Honeypot detection

Answer: C. The notes specifically describe wired side inputs as network management software using protocols like Telnet, SNMP, and CDP to detect devices connected to the LAN. **A is wrong:** RF scanning uses radio sensors, not CDP. **B is wrong:** AP scanning relies on neighboring APs reporting via MIB/web interface, not wired LAN protocols. **D is wrong:** honeypot detection is not one of the three rogue AP detection methods named in the notes.

Q8. During a WPA2 cracking engagement, which command correctly sends 11 de-authentication packets to force a target client to reconnect so a fresh handshake can be captured? A. airodump-ng --deauth 11 -a B. aireplay-ng -0 11 -a -c C. aircrack-ng --deauth 11 -w wordlist.txt capture.cap D. airmon-ng start --deauth 11

Answer: B. aireplay-ng is the injection tool; `-0 11` (equivalent to --deauth 11) sends 11 deauth frames, with `-a` for the AP BSSID and `-c` for the target client. **A is wrong:** airodump-ng only captures, it has no deauth/injection capability. **C is wrong:** aircrack-ng only cracks an existing capture file, it does not inject frames. **D is wrong:** airmon-ng only toggles monitor mode, it has no deauth function.

Q9. Which tool must run before Reaver to determine whether a target access point has WPS enabled and whether it is currently locked? A. aircrack-ng B. Wash C. hashcat D. Ettercap

Answer: B. Wash is the WPS-discovery utility that reports whether an AP advertises WPS and its lock state, feeding Reaver's target selection. **A is wrong:** aircrack-ng cracks keys, it does not check WPS status. **C is wrong:** hashcat cracks converted handshake files, unrelated to WPS discovery. **D is wrong:** Ettercap is used for ARP poisoning and MITM sniffing, not WPS discovery.

Q10. What is the primary root cause that KRACK exploits in the WPA2 4-way handshake? A. A weak RC4 stream cipher B. Reuse of a cryptographic nonce when Message 3 is replayed C. An unauthenticated CRC-32 checksum D. A default WPS PIN

Answer: B. KRACK forces the client to reinstall an already-used key by replaying handshake Message 3, causing nonce reuse. **A is wrong:** WPA2 uses AES-CCMP, not RC4; RC4 weakness is a WEP/WPA issue. **C is wrong:** CRC-32 with no authentication is a WEP weakness, not the WPA2/KRACK mechanism. **D is wrong:** default WPS PINs relate to Reaver-style attacks, not KRACK.

Q11. A set of vulnerabilities called Dragonblood allows an attacker to force a WPA3 client to fall back to a weaker protocol by exploiting backward compatibility. Which protocol is the client typically downgraded to? A. WEP B. WPA2 C. WPA3-Enterprise only D. Open/no security

Answer: B. The notes describe Dragonblood's downgrade attack as forcing the victim into WPA2 encryption, then applying standard WPA2 attacks. **A is wrong:** WEP is not the described fallback target in this attack. **C is wrong:** WPA3-Enterprise is not a "weaker" fallback, it is a different WPA3 mode, not a downgrade target. **D is wrong:** the notes describe a fallback to WPA2 specifically, not to an open, unencrypted network.

Q12. Which hashcat hash mode number should be used to crack a converted WPA-PBKDF2-PMKID+EAPOL capture file? A. 2500 B. 16800 C. 22000 D. 1000

Answer: C. Mode 22000 is the modern combined mode for WPA-PBKDF2- PMKID+EAPOL captures used in the notes' demo. **A and B are wrong:** these are older, now largely superseded mode numbers for similar but separated PMKID/EAPOL attacks in earlier hashcat versions. **D is wrong:** mode 1000 targets NTLM hashes, unrelated to Wi-Fi handshakes.

Q13. An attacker near a corporate office uses a high-gain amplifier to flood the 2.4 GHz band with noise, preventing any nearby device from transmitting because 802.11's CSMA/CA requires a period of silence first. Which threat family does this belong to? A. Integrity attack B. Confidentiality attack C. Availability attack D. Authentication attack

Answer: C. Denying the required silence period for CSMA/CA to deny service to legitimate users is squarely an availability attack (the notes list jamming under availability attacks alongside DoS and deauth floods). **A is wrong:** integrity attacks forge frames, they do not flood the spectrum with noise. **B is wrong:** confidentiality attacks intercept data content, not block transmission. **D is wrong:** authentication attacks steal identity/credentials, unrelated to radio jamming.

Q14. During an authorized assessment, a tester wants to use an AI chatbot to speed up building a Google dork command for Wi-Fi-related recon on a client's public assets. Which practice keeps this use of AI safe? A. Blindly execute whatever shell command the AI produces B. Review the generated command before executing it C. Give the AI tool root access so it can run commands itself D. Skip reviewing scope since the AI already knows it

Answer: B. As shown with ShellGPT-style tools in earlier CEH v13 modules, the tester must always review an AI-generated command before pressing execute, since LLMs can produce wrong or unsafe commands. **A is wrong:** blind execution risks running an incorrect or destructive command. **C is wrong:** granting root/autonomous execution removes the human safety check entirely. **D is wrong:** scope must always be confirmed by the human tester, never assumed from AI output.

Q15. A company deploys an AI-assisted wireless defense dashboard that continuously watches the RF spectrum, flags an Evil Twin using the corporate SSID, and estimates its physical location for the security team. Which category of defensive capability is this? A. One-time Wi-Fi discovery tool B. Wireless Intrusion Prevention System (WIPS) C. RFID cloning tool D. Hashcat cracking rig

Answer: B. Continuous RF monitoring that detects rogue/Evil Twin APs and can alert or respond automatically is the defining role of a WIPS, such as Cisco Adaptive Wireless IPS. **A is wrong:** discovery tools like inSSIDer are run on demand by a person, not continuously. **C is wrong:** RFID cloning tools duplicate badges, unrelated to Wi-Fi spectrum monitoring. **D is wrong:** hashcat is an offline password cracker, not a monitoring system.

Q16. Which WPA2 mode is most appropriate for an enterprise network that needs to assign unique login credentials per employee and revoke access individually when someone leaves? A. WPA2-Personal B. WPA2-Enterprise with RADIUS C. WEP with MAC filtering D. Open network with a captive portal

Answer: B. WPA2-Enterprise uses EAP/RADIUS to give each user unique credentials, letting IT revoke one person's access without changing a shared password. **A is wrong:** WPA2-Personal uses one shared passphrase for everyone, so revoking one person forces a reset for all. **C is wrong:** WEP is broken and MAC filtering is easily spoofed, neither provides real per-user accountability. **D is wrong:** an open network with a captive portal provides weak or no real wireless link encryption.

Q17. What is the key functional difference between a generic rogue access point and an Evil Twin? A. A rogue AP always uses encryption; an Evil Twin never does B. An Evil Twin specifically impersonates a trusted, known SSID; a rogue AP does not need to C. A rogue AP can only exist on a wired network D. An Evil Twin always requires RFID hardware

Answer: B. Every Evil Twin is a rogue AP, but it is specifically distinguished by copying a legitimate, trusted network's SSID to deceive users, while a generic rogue AP (for example, "Free Internet") does not need to impersonate anything. **A is wrong:** encryption presence is not the distinguishing factor for either category. **C is wrong:** rogue APs are wireless devices by definition in this module, not limited to wired-only existence. **D is wrong:** RFID is unrelated hardware, used for a completely different attack (section 3.29).

Q18. Which countermeasure directly defeats a WPS PIN brute-force attack carried out with Reaver? A. Enabling SSID cloaking B. Disabling WPS entirely C. Switching from WPA2 to WPA (TKIP) D. Increasing the AP's transmit power

Answer: B. Reaver depends entirely on WPS being enabled; disabling WPS removes the attack surface completely. **A is wrong:** SSID cloaking has nothing to do with WPS. **C is wrong:** switching to the weaker WPA/TKIP protocol would make the network less secure, not more, and does not affect WPS at all. **D is wrong:** transmit power affects signal range, not WPS PIN brute forcing.

Q19. An attacker near a cellular user sets up a fake base tower between the victim's phone and the real tower, then uses DNS spoofing to redirect the victim's browser to a malicious site. Which attack is this? A. Evil Twin B. aLTEr attack C. Wi-Jacking D. KRACK

Answer: B. The aLTEr attack specifically targets LTE/4G networks using a fake base tower and DNS spoofing, exactly as described. **A is wrong:** Evil Twin targets Wi-Fi SSIDs, not cellular towers. **C is wrong:** Wi-Jacking targets home routers via a Karma Wi-Fi attack and cached admin pages, not cellular towers. **D is wrong:** KRACK targets the WPA2 Wi-Fi 4-way handshake, unrelated to cellular towers.

Q20. Which single flag, when added to an aireplay-ng fake- authentication command, specifies zero reassociation delay while associating the attacker's card with a target AP? A. -0 0 B. -1 0 C. --deauth 0 D. -c 0

Answer: B. `-1 0` runs aireplay-ng's fake authentication mode with a reassociation delay of 0, as shown in the module's MITM demo. **A is wrong:** `-0` is the deauth mode flag, not fake authentication. **C is wrong:** `--deauth 0` would send zero deauth packets, which accomplishes nothing. **D is wrong:** `-c` specifies a client MAC in other contexts, it is not the fake-authentication mode flag.

Q21. Which Aircrack-ng suite tool can function as an ad-hoc access point to help capture a WPA/WPA2 handshake? A. airbase-ng B. airodump-ng C. airdecap-ng D. airdrop-ng

Answer: A. airbase-ng's documented role includes capturing WPA/ WPA2 handshakes and acting as an ad-hoc AP. **B is wrong:** airodump-ng only passively captures frames, it cannot act as an AP. **C is wrong:** airdecap-ng decrypts already-captured traffic. **D is wrong:** airdrop- ng performs targeted, rule-based deauthentication, not AP emulation.

Q22. A security team wants to prevent DNS-level redirection attacks like aLTEr on managed laptops. Which of the following is the most directly relevant control? A. Enabling DNS over HTTPS (DoH) with a trusted resolver B. Enabling WPS on all access points C. Disabling 802.1X authentication D. Lowering the AP transmit power

Answer: A. The notes list DoH, DoT, and DNSCrypt as direct countermeasures against aLTEr-style DNS spoofing. **B is wrong:** enabling WPS increases risk (Reaver attacks), it does not defend against DNS spoofing. **C is wrong:** disabling 802.1X removes a strong authentication control and has no bearing on DNS spoofing defense. **D is wrong:** transmit power affects physical range, not DNS integrity.

Q23. What does the output line "KEY FOUND! [12345678]" from aircrack-ng represent? A. The AP's BSSID B. The recovered WPA/WPA2 passphrase C. The WPS PIN D. The client's MAC address

Answer: B. This line is aircrack-ng's success message, printing the recovered pre-shared key/ passphrase from the wordlist attack. **A is wrong:** the BSSID is a MAC-format address, not a plaintext word like "12345678". **C is wrong:** WPS PINs are recovered by Reaver, not aircrack-ng, and are numeric with a specific checksum format. **D is wrong:** client MAC addresses appear in airodump-ng/aireplay-ng output, not as the "KEY FOUND" result.

Q24. Which best describes why MAC filtering alone is considered a weak wireless access control? A. MAC addresses are encrypted and cannot be read by sniffers B. MAC addresses are visible in cleartext frame headers and are trivially changed in software C. MAC filtering requires a RADIUS server, which most networks lack D. MAC filtering only works with WPA3

Answer: B. Even on encrypted Wi-Fi networks, 802.11 frame headers (including MAC addresses) are not encrypted, and tools can change a card's reported MAC in seconds. **A is wrong:** this is the opposite of reality; MAC addresses are visible in cleartext. **C is wrong:** MAC filtering does not require RADIUS; that is a separate, stronger control (802.1X). **D is wrong:** MAC filtering works independently of which encryption protocol (if any) is used.

Q25. A tester uses iCopy-X to capture and duplicate the data on an employee's building access badge. What category of attack is this? A. Wireless ARP poisoning B. RFID cloning C. Evil Twin D. Rogue AP

Answer: B. iCopy-X is specifically named in the notes as an RFID cloning device that captures and duplicates tag data. **A is wrong:** ARP poisoning manipulates IP-to-MAC mappings on a network, unrelated to physical badges. **C is wrong:** Evil Twin impersonates a Wi-Fi SSID, not a physical access card. **D is wrong:** a rogue AP is an unauthorized wireless access point, not a cloned badge.

10. Flashcards

Q: What does AP stand for in Wi-Fi? | A: Access Point, the device that bridges wireless clients to a wired network. Q: What is the 24-bit value WEP mixes with its key? | A: The Initialization Vector (IV). Q: Which cipher does WEP and WPA both use at their core? | A: RC4 (stream cipher). Q: What does TKIP stand for? | A: Temporal Key Integrity Protocol. Q: What integrity mechanism does WPA/TKIP add? | A: The Michael algorithm (MIC), plus CRC-32. Q: What cipher mode does WPA2 use? | A: AES-CCMP (Counter mode with CBC-MAC Protocol). Q: What is WPA3's key exchange called? | A: SAE, also known as Dragonfly Key Exchange. Q: What cipher does WPA3 use? | A: AES-GCMP-256. Q: Name the WPA2-Enterprise authentication server. | A: RADIUS (Remote Authentication Dial-In User Service). Q: What is the uncontrolled port used for in 802.1X? | A: Carrying only authentication traffic before full network access is granted. Q: What does CSMA/CA stand for? | A: Carrier Sense Multiple Access with Collision Avoidance. Q: Why does jamming cause a DoS on 802.11? | A: CSMA/CA requires a silent period before transmitting, and jamming denies that silence. Q: What is the first step of the wireless hacking methodology? | A: Wi-Fi Discovery. Q: What are the five wireless threat families? | A: Access control, Integrity, Confidentiality, Availability, Authentication. Q: Which tool enables monitor mode? | A: airmon-ng. Q: Which tool captures raw 802.11 frames? | A: airodump-ng. Q: Which tool injects deauth and fake-auth frames? | A: aireplay-ng. Q: Which tool cracks WEP and WPA/WPA2-PSK keys? | A: aircrack-ng. Q: Which tool decrypts captured WEP/WPA/WPA2 traffic? | A: airdecap-ng. Q: Which tool stores ESSID and password lists? | A: airolib-ng. Q: Which tool can act as a fake/ad-hoc AP? | A: airbase-ng. Q: What does Wash discover? | A: WPS-enabled access points and their lock state. Q: What does Reaver crack? | A: The WPS PIN. Q: Difference between disassociation and de-authentication? | A: Disassociation keeps auth intact (fast

reconnect); de-auth removes both auth and association. Q: What is an Evil Twin? | A: A rogue AP that copies a trusted SSID to trick users into connecting. Q: What is Hole196? | A: A WPA2 vulnerability letting an authenticated insider perform MITM/DoS attacks via GTK misuse. Q: What does KRACK exploit? | A: Nonce reuse caused by replaying Message 3 of the WPA2 4-way handshake. Q: What is Dragonblood? | A: A set of WPA3 SAE/Dragonfly vulnerabilities enabling downgrade and side-channel attacks. Q: Name the four Dragonblood tools. | A: Dragonslayer, Dragonforce, Dragondrain, Dragontime. Q: What tool converts a capture file for hashcat? | A: hcxpcapngtool. Q: Which hashcat mode cracks WPA-PBKDF2-PMKID+EAPOL captures? | A: 22000. Q: What is a Karma attack? | A: A rogue AP that answers "yes" to any SSID a nearby device probes for. Q: What does Wi-Jacking ultimately steal? | A: The victim's own router's admin credentials and WPA2 PSK. Q: What is RFID cloning? | A: Copying a legitimate RFID tag's data onto a blank chip to duplicate it. Q: What does the aLTEr attack target? | A: LTE (4G) cellular networks, using a fake tower and DNS spoofing. Q: Name three DNS countermeasures against aLTEr. | A: DNS over HTTPS (DoH), DNS over TLS (DoT), and DNSCrypt. Q: What is a WIPS? | A: A Wireless Intrusion Prevention System that monitors RF for threats and can respond automatically. Q: Name two rogue AP detection methods besides wired side inputs. | A: RF scanning and AP scanning. Q: Why is SSID cloaking considered weak security? | A: It can be defeated by sniffing probe responses or brute forcing with mdk3. Q: What should be disabled in WPA3 once all devices support it? | A: Transition mode (backward compatibility with WPA2). Q: Recommended minimum passphrase length as a countermeasure? | A: 12 to 16 characters, mixed character types.

11. Glossary

Access Point (AP): hardware that bridges wireless clients to a wired network. AES (Advanced Encryption Standard): a strong block cipher used in WPA2/WPA3. aLTEr attack: an attack using a fake LTE tower and DNS spoofing to redirect a victim's traffic. ARP (Address Resolution Protocol): maps IP addresses to MAC addresses on a local network; has no built-in authentication. BSSID: the MAC address that uniquely identifies an access point. CCMP: Counter mode with CBC-MAC Protocol, the AES-based mode used by WPA2. CRC-32: a checksum used by WEP; detects accidental errors, not deliberate tampering. CSMA/CA: Carrier Sense Multiple Access with Collision Avoidance, the 802.11 channel access method. Deauthentication attack: forged frame that removes both authentication and association from a client. Disassociation attack: forged frame that removes association but leaves authentication intact. Dragonblood: a set of vulnerabilities in WPA3's SAE/Dragonfly handshake. EAP (Extensible Authentication Protocol): a framework for carrying different authentication methods over 802.1X/RADIUS. Evil Twin: a rogue AP that copies a trusted SSID to trick users. GCMP-256: Galois/Counter Mode Protocol with a 256-bit key, used in WPA3. Hole196: a WPA2 vulnerability allowing an authenticated insider to perform MITM/DoS via GTK misuse. IV (Initialization Vector): a random value mixed with a key so repeated plaintext does not produce repeated ciphertext. Jamming: flooding the radio spectrum with noise to deny service. Karma attack: a rogue AP technique that answers "yes" to any SSID a device probes for. KRACK (Key Reinstallation Attack): an attack that forces nonce reuse by replaying Message 3 of the WPA2 4-way handshake. MAC spoofing: changing a network card's reported MAC address to bypass filtering. MANA Toolkit: a rogue

AP / Karma attack framework built on hostapd. MIC (Message Integrity Check): WPA's per-frame integrity check using the Michael algorithm. MITM (Man-in-the-Middle): an attacker positioned between a client and an AP, reading or altering traffic. Nonce: a "number used once" in a cryptographic exchange; reuse breaks security guarantees. PMK (Pairwise Master Key): the master key derived from the WPA/WPA2 passphrase, used to build session keys. PSK (Pre-Shared Key): a single shared password used for WLAN authentication. RADIUS (Remote Authentication Dial-In User Service): a centralized server for authentication, authorization, and accounting. Reaver: a tool that brute forces the WPS PIN. RFID (Radio Frequency Identification): short-range tag technology used in access badges and key fobs. RFID cloning: duplicating a legitimate RFID tag's data onto a blank chip. Rogue AP: any unauthorized access point providing backdoor network access. SAE (Simultaneous Authentication of Equals): WPA3's password-based key exchange, also called Dragonfly. SSID: the broadcast name of a wireless network. TKIP (Temporal Key Integrity Protocol): WPA's per-packet key mixing scheme that patches RC4/WEP weaknesses. WEP (Wired Equivalent Privacy): the original, broken 802.11 encryption standard. Wi-Jacking: an attack chain that steals a victim's own router admin credentials via Karma and a cached malicious page. WIPS (Wireless Intrusion Prevention System): a system that monitors RF for threats and can respond automatically. WPA (Wi-Fi Protected Access): the TKIP-based patch for WEP weaknesses. WPA2: the AES-CCMP based, mandatory-strength Wi-Fi security standard. WPA3: the newest Wi-Fi security standard using SAE and AES-GCMP-256. WPS (Wi-Fi Protected Setup): a simplified PIN/button Wi-Fi join feature, vulnerable to PIN brute force.

12. Coverage Report

Page-to-section mapping:

Page(s)	Topic	Guide section(s)
1	Learning objectives	3.1
2	Wireless networks, standards	3.2, 3.3
3	Authentication process, WEP	3.4, 3.5
4	WPA, WPA2 encryption	3.6, 3.7
5	WPA3 encryption	3.8
6	Protocol comparison, issues	3.9
7	Wireless threats (5 families)	3.10
8	Methodology, Wi-Fi footprinting	3.11, 3.12
9	Finding networks, WPS discovery	3.13, 3.14
10	Traffic analysis, card selection	3.15, 3.16
11	Aircrack-ng suite, hidden SSID	3.17, 3.18
12	Hidden SSID (cont), DoS attacks	3.18, 3.19
13	MITM concept and demo	3.20

Page(s)	Topic	Guide section(s)
14	MAC spoofing	3.21
15	ARP poisoning, Ettercap	3.22
16	Rogue APs, MANA Toolkit	3.23
17	Evil Twin, KRACK	3.24, 3.25
18	KRACK (cont), jamming	3.25, 3.26
19	Jamming devices, aLTEr	3.26, 3.27
20	Wi-Jacking, RFID cloning	3.28, 3.29
21	WPA/WPA2 cracking concepts/ demo	3.30
22	Fern Wifi Cracker, WPA3 cracking	3.31, 3.32
23	WPA3 cracking (cont), hashcat	3.32, 3.33
24	Reaver, countermeasures	3.34, 3.35
25	Rogue AP detection, best practices	3.36, 3.37
26	Wi-Fi security auditing tools	3.38

[UNCLEAR] items:

- [UNCLEAR on page 2] The exact SHODAN-style search keywords were not present in this module's screenshots in a readable form; none were needed for Module 16 content (this note mirrors the format used for genuinely blurry text elsewhere in the source).
- [UNCLEAR on page 11] Part of the mdk3 demo's recovered SSID list in the source screenshot was cut off; the "ECC Labs" result is confirmed, but one or two additional short recovered SSID strings earlier in the same run were not fully legible.
- [UNCLEAR on page 20] The precise sixth step of the Wi-Jacking attack (how the malicious page persists in the router admin origin) is summarized from a dense paragraph in the source; the mechanism is given as described, but exact technical wording beyond what is in section 3.28 should be verified against original research if used in a lab.
- [UNCLEAR on page 23] The Dragonfly AKE handshake diagram on this page was partly covered by decorative artwork in the source screenshot; only the surrounding bullet text (side-channel attacks) could be confirmed and is covered in section 3.32.

Items to double-check (marked "verify" in the guide):

- Exact 802.11a 3.7 GHz variant range figure (section 3.3).
- Exact modulation scheme used by 802.11be (section 3.3).
- Current RADIUS port numbers (1812/1813 vs legacy 1645/1646) in your specific lab/exam reference material (section 6).
- Current hashcat hash-mode numbering (22000 vs older 2500/16800) for the hashcat version actually installed in any hands-on practice (section 3.33, 5.8).

- Jamming device range/antenna/time specifications in section 3.26 are vendor marketing figures from the source screenshots, not independently verified engineering specifications.

Coverage confirmation: Every page and screenshot listed in the source transcript (pages 1 through 26, all screenshots in each page) has been placed into exactly one topic section in Section 3, and every tool, command, flag, protocol, port, acronym, attack, and countermeasure named in those screenshots appears in Section 3 and is cross-referenced in Sections 4 through 11.